



Security findings. Human decisions. Traceable evidence.

AI AGENT + MCP SECURITY REVIEW

Scan c0c0f6762caca66aa1694ccc9c8c93dc9356bfc0ee3244903cfbc814791d88ea

Critical/high findings need prompt review

The scanner found 8 open critical/high patterns among 11 open findings. Confirm exposure and prioritize the actions below. Detector severity is not proof of exploitability or deployed risk.

11

OPEN FINDINGS

0

COVERAGE GAPS

3

FILES EXAMINED

Observed counts only. This is not an accuracy score or a security grade.

Optional model review: finding stage error; control stage error. 132 acceptance checks remain unanswered. Requested work is incomplete. Inspect the recorded errors; no model judgment resolves the static findings.

This PDF contains interactive review fields and the exact bound review workspace as an attachment. Decisions are human assertions, not verified passes. Justified/disabled items are excluded from active denominators; gaps cannot be waived.

Save an edited copy and import it through Invarune. The importer checks origin/evidence bindings, canonical form data, widget relationships and appearances. Changed source, stale appearances or ambiguous fields are rejected.



Contents

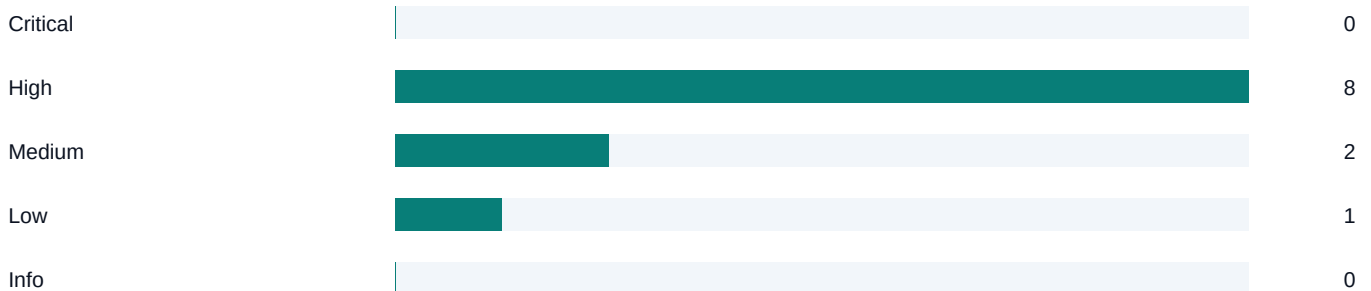
Contents	2
Executive summary	3
Scan configuration and scope	4
Deterministic checks and optional review	5
Coverage, misses and validation by area	6
Deterministic rule inventory	8
Observed findings and mitigating layers	11
Optional advisory review and evidence	23
Coverage gaps and required validation	38
Interactive review workspace	39
Control checklist and evidence requirements	111



Executive summary

Optional model review: finding stage error; control stage error. 132 acceptance checks remain unanswered. Requested work is incomplete. Inspect the recorded errors; no model judgment resolves the static findings.

Severity counts describe observed open patterns. They do not establish exploitability or an estimated probability of compromise.



Severity counts use the existing scanner rules; no model or reviewer score is added.

Fix guidance: 11/11 findings have deterministic fix plans and agent/MCP context. Model fix plans: 0/0 finding assessments; 0/0 answered checks. Proposals require verification.

AI001 / Dynamic Python code execution

Trace the input to eval/exec and replace it with fixed operations; if generated execution is essential, isolate it before accepting untrusted input.

AI002 / Dynamic command executed through a shell

Remove shell interpretation, select a fixed executable, and validate each argument and permitted option.

AI003 / Dynamic os shell command

Replace os.system/os.popen with a fixed executable and validated argument list; trace all contributing values.

AI005 / Executable deserialization requires trusted inputs

Establish who can produce and replace the input; migrate to a nonexecutable data format or restrict verified legacy artifacts to an isolated conversion path.

AI006 / TLS certificate verification disabled

Enable certificate and hostname verification; install the intended CA for a private gateway and test rejection of an untrusted certificate.

AI010 / Credential-like literal in source or configuration

Determine whether the value is real without reproducing it; revoke or rotate a real exposed credential and remove retained copies through the incident process.

AI029 / Remote MCP URL uses plaintext HTTP

Use HTTPS with verified certificates; if a separate protected transport is intentional, document and test every network hop and termination boundary.

AI031 / Agent approval or sandbox safeguard explicitly bypassed

Review the effective permission policy and restore bounded tools and runtime isolation; require independent approval for the specific sensitive effects.

Review every detailed finding and gap below. Additional concerns can exist outside this bounded scan's supported syntax, files, budgets and execution context.



Scan configuration and scope

Source scope and limits

default_excluded_directories: [".cache", ".git", ".hg", ".mypy_cache", ".next", ".pytest_cache", ".svn", ".tox", ".venv", "__pycache__", "build", "coverage", "dist", "node_modules", "vendor", "venv"]

exclude: []

explicit_exclusion_identity_scope: "Existing selected files and directories, including case aliases and file hardlinks; inputs must remain stable during the scan. Device/inode identities are not persisted in reports."

explicit_exclusion_matching: "resolved_paths_and_snapshot_filesystem_identities"

generated_outputs_and_judge_config_excluded: true

max_entries: 100000

max_file_bytes: 1000000

max_files: 20000

max_total_bytes: 50000000

Invocation and optional-review budgets

optional_review: {"analyst_limits": {"batch_size": 6, "max_bytes": 2000000, "max_calls": 12, "max_chars": 120000, "max_files": 200, "max_seconds": 600.0}, "cli_login": "never", "cli_timeout_seconds": 120.0, "effective_transport": {"max_request_bytes": 524288, "max_response_bytes": 1048576, "model": "opus", "provider": "claude_cli", "timeout_seconds": 120.0}, "enabled": true, "findings_limit": 100, "include_finding_source": true, "mode": "full", "provider": null, "transport_replay": "Endpoints, credentials, headers, executable paths and identity stores are not embedded for automatic replay."}

reporting: {"failure_threshold": "high", "formats": ["html", "markdown", "json", "sarif", "pdf"]}

review_inputs: {"baseline": false, "review_config": false, "review_report": false}

schema_version: "1.0"

Image limits

Not present for this scan.

Source and image evidence are static. Image metadata, retained layers and packaged files do not reveal every runtime override or compiled program behavior.

Tool provenance: {"display_name": "Invarune by NimeshBuild", "implementation_sha256": "b2ed4a3b8f476586fd723d45c68c388d13874b09ab451d9a61c74cf57874d426", "name": "agent-mcp-security-scan", "python_version": "3.12.14", "version": "0.10.0"}



Deterministic checks and optional review

42 static source/configuration patterns

Deterministic checks inspect bounded Python syntax and local value flow, JavaScript/TypeScript lexical structure, structured JSON, configuration settings, selected secret patterns and image metadata. Repeated stable input produces repeatable evidence; it does not guarantee zero false positives or negatives.

Optional security analyst

If enabled, a model reviews selected findings and acceptance checks using bounded supplied evidence. Strict IDs, citations, response validation and tool restrictions constrain the protocol. Partial budgets, omitted answers and unavailable source/runtime evidence remain visible. Advice does not independently prove safety or erase static findings.

```
{
  "analyst": {
    "check_status_counts": {
      "insufficient_evidence": 132,
      "coverage": {
        "attempted_controls": 0,
        "call_budget": 12,
        "calls_made": 0,
        "catalog_checks": 132,
        "catalog_controls": 66,
        "disabled_checks": 0,
        "disabled_controls": 0,
        "evidence": {
          "collection_status": "not_started"
        },
        "excluded_checks": 0,
        "excluded_controls": 0,
        "justified_checks": 0,
        "justified_controls": 0,
        "omitted_checks": 132,
        "reviewed_controls": 0,
        "total_checks": 132,
        "total_controls": 66,
        "unreviewed_control_ids": [
          "GOV-01", "GOV-02", "GOV-03", "GOV-04", "GOV-05", "GOV-06", "AUTH-01", "AUTH-02", "AUTH-03", "AUTH-04", "AUTH-05", "AUTH-06", "AUTH-07", "AUTH-08", "AUTH-09", "MCP-01", "MCP-02", "MCP-03", "MCP-04", "MCP-05", "MCP-06", "MCP-07", "MCP-08", "MCP-09", "MCP-10", "AGT-01", "AGT-02", "AGT-03", "AGT-04", "AGT-05", "AGT-06", "AGT-07", "EXEC-01", "EXEC-02", "EXEC-03", "EXEC-04", "EXEC-05", "EXEC-06", "EXEC-07", "DATA-01", "DATA-02", "DATA-03", "DATA-04", "DATA-05", "DATA-06", "SUP-01", "SUP-02", "SUP-03", "SUP-04", "SUP-05", "SUP-06", "OPS-01", "OPS-02", "OPS-03", "OPS-04", "OPS-05", "OPS-06", "TEST-01", "TEST-02", "TEST-03", "TEST-04", "TEST-05", "TEST-06", "TEST-07", "TEST-08", "TEST-09"
        ],
        "validated_controls": 0,
        "enabled": true,
        "errors": [
          "Control review was not started because finding triage or judge configuration failed."
        ],
        "status": "error",
        "judge": {
          "enabled": true,
          "error": "CLI sign-in is missing or expired."
        }
      },
      "omitted_open_findings": 0,
      "selected_findings": 11,
      "source_context_sent_count": 11,
      "source_context_skipped": [],
      "status": "error"
    }
  }
}
```

What can be missed

Cross-module/interprocedural flow, reflection, dynamic loaders, complex language syntax, templates before rendering, unsupported languages, compiled image behavior, runtime authentication/authorization, tenant isolation, egress policy, dependency CVEs and adaptive prompt injection require additional validation. A source declaration or proposed mitigation is not deployment evidence.

Human/runtime review workflow

1 / SELECT

Source or built image

2 / INSPECT

Deterministic evidence

3 / OPTIONAL

Bounded analyst review

4 / VALIDATE

Runtime / human tests

5 / RECORD

Decision + reason + owner

6 / RECHECK

Fresh scan + bound import

1. Review evidence and the immediate concern. 2. Record a decision, reason, reviewer, date and evidence reference. 3. Validate runtime or human-dependent controls in the applicable environment. 4. Save and import the edited PDF or equivalent JSON. 5. Resolve rejected/stale edits, then rescan. Gaps remain operationally incomplete; blank decisions retain existing scanner semantics.



Coverage, misses and validation by area

Controls with rule mapping		26
Controls without rule mapping		40

Catalog mapping counts are not passed controls or percent secure.

Mapping counts describe available checks, not percent secure, detection accuracy or validated control effectiveness.

Execution and data flow

Deterministic: Python AST checks with bounded local aliases/values; JavaScript/TypeScript tokens and balanced calls identify selected eval, shell, deserialization, SQL and template patterns.

Optional analyst: A model can explain a retrieved call path, question whether input is trusted and identify contextual concerns the pattern rules do not encode.

Can miss or misclassify: Cross-file flows, dynamic imports, wrappers, reflection, generated code, unsupported languages and runtime values can hide a risk. A dangerous API can also be intentional and correctly constrained.

Validate elsewhere: Exercise actual entry points with authorized negative tests; verify input provenance, execution privileges and sandbox boundaries.

MCP identity, authorization and tools

Deterministic: Selected configuration/code signals flag insecure transport, explicit authentication bypass, token passthrough, broad tool grants and unpinned server launch packages.

Optional analyst: A model can review supplied authorization logic, tool descriptions and trust-boundary evidence for missing assumptions or inconsistent checks.

Can miss or misclassify: Configuration may differ from deployment. External gateways, identity providers, token audience checks and tenant boundaries may be absent from retrieved evidence.

Validate elsewhere: Test expired/wrong-audience tokens, cross-tenant access, per-tool authorization, consent binding and the deployed MCP transport.

Prompt injection, retrieval and memory

Deterministic: Selected patterns identify external content placed in privileged model messages and explicit approval/sandbox bypass. This is not an attack simulation.

Optional analyst: A model can reason about untrusted-content handling, persistent memory, tool-output influence and missing approval boundaries in the supplied excerpts.

Can miss or misclassify: Adaptive attacks, multi-turn interactions and tool chains depend on runtime behavior. Retrieval can omit the relevant code; a model can overlook an attack or be influenced by hostile evidence.

Validate elsewhere: Run isolated adversarial agent/MCP evaluations with attack-success and legitimate-task measurements, plus human review of consequential actions.

Secrets and data handling

Deterministic: Selected literal credentials, plausible private-key material, credential-bearing URLs, logging patterns and browser credential exposure are flagged and redacted best-effort.

Optional analyst: A model can identify sensitive data flows and retention concerns when the supplied evidence explains their context.

Can miss or misclassify: Encoded, split or runtime-fetched credentials can be missed; labels/test values can resemble secrets. Neither layer establishes whether a credential is live or redaction is complete.

Validate elsewhere: Verify secret stores, credential rotation, logging/retention policy, egress destinations and actual data-access permissions.

Built images and supply chain

Deterministic: Image archives are reconstructed without starting containers; supported packaged source, metadata, retained credentials, stored permissions and package inventories are inspected.

Optional analyst: A model can interpret supplied image/source evidence, flag missing deployment context and propose verification work.

Can miss or misclassify: Compiled logic, live deployment overrides, signature trust and dependency CVEs are not assessed. Package inventory and archive consistency do not establish safety or publisher identity.

Validate elsewhere: Use vulnerability/advisory analysis, provenance/signature verification and deployment testing alongside the static image assessment.



Operations and control effectiveness

Deterministic: The catalog retains governance, monitoring, recovery, approval and isolation checks even where no deterministic rule maps to them.

Optional analyst: Full review queues every active acceptance check and can identify evidence gaps or propose runtime/human validation; it can cite exact submitted source text.

Can miss or misclassify: A valid citation proves that a quote exists, not that the model's interpretation is correct. Policies, external services, incident procedures and production outcomes may be unavailable.

Validate elsewhere: Record owner-reviewed evidence, operational exercises and runtime results. A written justification remains an accepted exception, never an automatically validated pass.



Deterministic rule inventory

AI001 / Dynamic Python code execution

eval or exec receives a nonliteral expression. If agent, user, or tool content can reach it, it can execute arbitrary Python. Static analysis does not establish the full data flow.

AI002 / Dynamic command executed through a shell

A subprocess call enables a shell, invokes a shell-specific API, or passes a dynamic command to an explicit shell executable. Shell metacharacters in agent or external input may become executable syntax.

AI003 / Dynamic os shell command

os.system or os.popen executes a dynamically constructed command through the shell. Review the command's trust boundary.

AI004 / Unsafe YAML object construction

YAML is loaded through an unsafe loader or without an explicitly safe loader. Older or unsafe loaders can construct Python objects from input.

AI005 / Executable deserialization requires trusted inputs

Pickle-compatible deserialization can execute code. This finding identifies a dangerous trust boundary, not proof that the serialized input is attacker controlled.

AI006 / TLS certificate verification disabled

Certificate verification is explicitly disabled. A network intermediary may impersonate the remote service and capture prompts, credentials, or tool results.

AI007 / Wildcard cross-origin access

Cross-origin access explicitly permits every origin. For credential-bearing or local MCP services this can expose a browser-accessible trust boundary; reachability and framework behavior require review.

AI008 / Service binds to all network interfaces

A server explicitly binds to a wildcard address. This is a deployment review signal: source alone cannot establish actual network reachability or authentication.

AI009 / Application debug mode enabled

Debug mode is explicitly enabled in server code or configuration. Depending on the framework and deployment, error details or a debugger may become externally accessible.

AI010 / Credential-like literal in source or configuration

A credential-named field contains a nonplaceholder literal. It may be a real secret or test data; validate it without disclosing the value.

AI011 / Private key material in repository

A private-key PEM header is followed by plausible encoded key material. Test keys may be intentional; this pattern does not prove cryptographic validity or production use.

AI012 / Dynamic JavaScript shell execution

A Node child-process shell execution API receives a dynamic command. Agent or external content reaching this value may inject shell syntax.

AI013 / Dynamic JavaScript code execution

eval or the Function constructor evaluates a dynamic value as JavaScript. Review whether user, agent, or tool data can cross this execution boundary.

AI014 / Externally influenced outbound request

An outbound request uses an obvious external-input expression. This is a review signal for SSRF; this local analysis cannot prove whether upstream URL validation exists.

AI015 / Externally influenced filesystem path

A filesystem operation consumes an obvious external-input expression. Review whether canonical path checks and symlink handling confine access to the intended workspace.

AI016 / Race-prone temporary filename creation

tempfile.mktemp returns an unused name without atomically creating the file, allowing a race with another local process.



AI017 / JWT verification explicitly bypassed

JWT decoding explicitly disables signature verification or selects the none algorithm. Unverified claims must never authorize agent or MCP operations.

AI018 / MCP package runner resolves an unpinned artifact

An MCP launch configuration uses npx, uvx, or a similar ephemeral package runner without an exact package version. The executable artifact can change between launches.

AI019 / Remote download piped directly to a shell

Downloaded content is directly piped to a shell. A changed or compromised remote artifact becomes executable without a visible integrity check.

AI020 / GitHub Action reference is not pinned to a commit

A remote GitHub Action is referenced using a mutable tag, branch, or noncommit reference. Its code can change without a workflow diff.

AI021 / Container explicitly runs as root

The default final Dockerfile stage explicitly selects or inherits a literal root user. Build-target selection, external image defaults, variable expansion and runtime overrides require separate validation.

AI022 / Privileged container or privilege escalation enabled

Container configuration explicitly enables privileged execution or privilege escalation, weakening isolation for tool or agent code.

AI023 / Container runtime socket exposed

A container runtime socket is present in configuration. A writable Docker or containerd socket can give a tool control over host workloads.

AI024 / Container image is not digest pinned

A container base or deployment image uses a mutable reference rather than a content digest. The bytes can change between builds or deployments.

AI025 / Direct dependency is not exactly pinned

A direct dependency declaration allows version movement. A lockfile elsewhere may constrain the actual installation; review the effective build process.

AI026 / Authentication explicitly disabled

An MCP or server configuration explicitly disables an authentication-related control. Local stdio servers may rely on an operating-system boundary; assess the actual transport and exposure.

AI027 / Wildcard tool or permission authorization

An authorization or tool allowlist explicitly grants a wildcard or all-tools capability. This may give an agent broader authority than its task requires.

AI028 / MCP token passthrough enabled

Configuration explicitly enables token passthrough or token forwarding. Forwarding an inbound token to an unrelated downstream audience can bypass consent and authorization boundaries.

AI029 / Remote MCP URL uses plaintext HTTP

An MCP configuration points to a nonloopback HTTP URL. Credentials, tool requests, and results may be exposed in transit; network-layer protection is not established by this scan.

AI030 / Browser-side API credential access explicitly enabled

An SDK explicitly enables browser execution despite credential-exposure safeguards. Verify that a durable privileged API key cannot reach client-side code.

AI031 / Agent approval or sandbox safeguard explicitly bypassed

An agent configuration or command explicitly disables approvals or enables unrestricted execution. The impact depends on the process identity, tools, and sandbox.

AI032 / External data inserted into privileged LLM instructions

A system or developer message contains an obvious external-input expression. Untrusted data may be interpreted as privileged instructions; local analysis cannot establish exploitability.

AI033 / Potential secret included in logging call

A logging call directly references a credential-named variable or field. Log processors and retention can broaden access to secrets.

AI034 / Credential-like value embedded in URL query

A URL contains a credential-like query parameter with a nonplaceholder value. URLs can be retained in logs, histories, proxies, and telemetry.



AI035 / Unsafe model checkpoint deserialization

torch.load explicitly sets weights_only=False or a framework disables safe model loading. An untrusted artifact may contain executable object deserialization.

AI036 / SQL query constructed with interpolation

A database execution call receives an interpolated or concatenated SQL expression. If untrusted content contributes, it may change the query's meaning.

AI037 / Archive extraction without an explicit safe filter

A tar extraction call has no explicit safe data filter, or selects a fully trusted filter. Behavior depends on the Python version and archive provenance.

AI038 / Cryptographically weak randomness used for a security value

A credential-, nonce-, or token-named assignment uses a general-purpose random generator. Predictability matters if the value protects access or replay prevention.

AI039 / Server-Side Template rendered from a dynamic template

A server-side template string is dynamically supplied. If agent or user content controls template source, template expressions may execute with server privileges.

AI040 / Unsafe HTML rendering boundary

Dynamic content is passed to an HTML rendering bypass. Agent or tool-generated content may contain executable browser markup if not sanitized.

AI041 / MCP inspector authorization explicitly disabled

The MCP inspector's authorization safeguard is explicitly disabled. A reachable inspector may provide access to connected tools and their privileges.

AI042 / Container uses host namespaces

Container configuration explicitly uses the host PID namespace or host networking. This weakens separation between agent tooling and the host.



Observed findings and mitigating layers

AI002 / high / open

Dynamic command executed through a shell

agent.py:9

```
subprocess.run(user_command, shell=True)
```

Pass an argument list with shell=False, allowlist executable names and options, and enforce working-directory and resource restrictions.

Fix plan and agent/MCP relevance

Remove shell parsing and constrain the actual executable and its arguments.

Why this matters for agents/MCP: An agent or MCP tool often translates model-selected operations into subprocess commands. Untrusted arguments embedded in a shell string can turn one permitted tool action into additional commands.

Inspect the reported source location and its callers, change the implementation or effective configuration, then rebuild and rescan. The scan does not establish that this code is on an active agent or MCP request path.

Confirm applicability: Determine whether each dynamic component can be influenced by user, retrieval, model or tool content.

Confirm applicability: shell=False is insufficient when the selected program is itself sh, bash, cmd, PowerShell or another interpreter receiving generated code.

1. Use a fixed process invocation

Replace shell=True and shell-specific helpers with subprocess.run using an argument list, shell=False, a fixed executable path and an explicit timeout. Replace pipelines with separate bounded calls or native library operations.

Verify: Submit spaces, quotes and shell metacharacters as data to a harmless test executable; assert the expected argument vector and that no additional process starts.

2. Validate argument meaning

Allowlist flags and resource identifiers, reject caller-selected executables, and use an end-of-options delimiter only where the chosen utility supports it. Do not treat shlex.split or shell quoting as authorization.

Verify: Test leading-dash filenames, unexpected flags and an interpreter executable; verify policy blocks them before process creation.

3. Constrain process authority

Set a permitted working directory and minimal environment, bound output and runtime, and apply a separate low-privilege execution identity where required. Review Windows batch-file behavior on the actual platform.

Verify: Run denial tests for forbidden files, inherited credentials and excessive output on each deployed operating system.

Remaining validation: Argument arrays prevent shell parsing but cannot prevent dangerous valid options or harmful allowed operations.

Remaining validation: Process timeouts do not by themselves establish descendant-process cleanup or OS isolation.

Related controls: EXEC-01

[REM-PY-SUBPROCESS / Python subprocess: security considerations](#)

[OWASP-AGENT-CS / AI Agent Security Cheat Sheet](#)

AI003 / high / open

Dynamic os shell command

agent.py:10

```
os.system(user_command)
```

Use subprocess with a fixed executable and argument list, shell=False, and explicit allowed options.

Fix plan and agent/MCP relevance

Replace os.system/os.popen with a fixed executable and validated argument list.

Why this matters for agents/MCP: An MCP command tool may interpolate planner output into os.system or os.popen. Those APIs introduce a shell boundary that can expand attacker-controlled syntax into the server account privileges.

Inspect the reported source location and its callers, change the implementation or effective configuration, then rebuild and rescan. The scan does not establish that this code is on an active agent or MCP request path.

Confirm applicability: Inspect the command construction and upstream validation at the reported call; this rule does not prove an attacker can supply the value.

Confirm applicability: If the operation is file copying, listing or parsing, a dedicated library API often removes the shell requirement entirely.



1. Remove os shell APIs

Replace the operation with a native library call or `subprocess.run([fixed_executable, validated_argument], shell=False, timeout=...)`. Split intentional pipelines into explicit stages with bounded output.

Verify: Use a harmless fixture containing shell metacharacters and assert it is processed as one argument or rejected, without a second command.

2. Restrict operations before execution

Bind the tool name to a fixed executable and authorized workspace; validate flags and resource ownership independently of the prompt and of shell escaping.

Verify: Call the server directly with an unauthorized path, extra option and different executable; verify rejection even without the agent planner.

3. Close inherited authority

Supply a minimal environment, avoid carrying gateway/cloud credentials into the child, and enforce cancellation plus output limits.

Verify: Inspect the test child environment and attempt an overlong operation; confirm sensitive variables are absent and the process is stopped.

Remaining validation: A correctly formed command can still modify the wrong tenant resource; policy enforcement and runtime identity remain necessary.

Related controls: EXEC-01

REM-PY-SUBPROCESS / Python subprocess: security considerations

MCP-TOOLS / MCP: Tools

AI006 / high / open

TLS certificate verification disabled

agent.py:11

```
data = requests.get(remote_url, verify=False)
```

Enable certificate verification and install the correct CA bundle; use a trusted private CA for custom gateways.

Fix plan and agent/MCP relevance

Restore certificate and hostname verification, including custom gateways.

Why this matters for agents/MCP: The affected connection can carry model credentials, prompts, MCP tool requests or retrieved evidence. Disabling TLS verification lets a reachable intermediary impersonate that peer and influence both data and agent decisions.

Inspect the reported source location and its callers, change the implementation or effective configuration, then rebuild and rescan. The scan does not establish that this code is on an active agent or MCP request path.

Confirm applicability: Confirm which client and effective session settings apply; the detected literal does not prove this connection is used in production.

Confirm applicability: A private gateway CA is a trust-distribution requirement, not a reason to disable peer verification.

1. Restore authenticated TLS

Remove `verify=False`, `CERT_NONE` and `hostname-check` bypasses. Use the client default trust store or supply an approved CA bundle through its supported verification setting.

Verify: Against a test endpoint, reject an untrusted certificate and wrong hostname while accepting the intended certificate chain.

2. Provision gateway trust explicitly

Distribute the private CA through the runtime trust configuration, verify the configured gateway hostname, and document CA rotation. Keep credentials out of URL query strings and diagnostics.

Verify: Exercise certificate renewal and CA rollover in a staging environment; confirm the client never retries with verification disabled.

3. Inspect effective runtime overrides

Check environment variables, shared HTTP sessions, proxies and image/deployment configuration for remaining bypasses on model and MCP clients.

Verify: Run the actual deployment client through the intended proxy/gateway and retain handshake results plus redacted configuration evidence.

Remaining validation: Valid TLS authenticates the endpoint name, not the endpoint operator trustworthiness or its data-retention practices.

Related controls: MCP-01

REM-REQUESTS-TLS / Requests: SSL certificate verification

MCP-SECURITY / MCP Security Best Practices

AI005 / high / open

Executable deserialization requires trusted inputs

agent.py:12



```
return pickle.loads(serialized_data), data.text
```

Use a nonexecutable serialization format with schema validation. If compatibility requires pickle, accept only authenticated artifacts from a strictly controlled producer.

Fix plan and agent/MCP relevance

Replace executable object deserialization or tightly authenticate its producer.

Why this matters for agents/MCP: A cached agent state, plugin artifact or MCP-uploaded file may reach pickle-compatible loading. Deserialization can execute producer-selected code before downstream data validation.

Inspect the reported source location and its callers, change the implementation or effective configuration, then rebuild and rescan. The scan does not establish that this code is on an active agent or MCP request path.

Confirm applicability: Identify the producer and every write path to the artifact, including shared caches, object stores and task workspaces.

Confirm applicability: The finding identifies a dangerous loader; it does not show that its input is attacker controlled.

1. Migrate to data-only serialization

Replace pickle, dill, joblib or equivalent object loading with JSON or another nonexecutable format plus a versioned schema. Reconstruct only explicitly supported application types.

Verify: Roundtrip required benign state and reject unexpected type markers, fields and oversized collections without importing producer-selected code.

2. Control unavoidable legacy artifacts

If compatibility requires executable deserialization, authenticate the exact bytes against a producer/key or registry digest established independently of the artifact location. Restrict cache and artifact writers.

Verify: Alter one byte and change the producer identity in test artifacts; verify rejection before the deserializer is called.

3. Quarantine conversion

Convert legacy artifacts in a disposable credential-free worker with resource and network limits, then export validated data to the main service.

Verify: Verify conversion cannot read main-service secrets or contact forbidden destinations and that failed conversions publish no partial trusted state.

Remaining validation: A valid signature identifies a producer; it does not make a compromised or malicious producer safe.

Remaining validation: Schema validation after pickle loading is too late to prevent execution during loading.

Related controls: EXEC-06

[TECH-PYTHON-SECURITY / Python Security Considerations](#)

[JOINT-DEPLOY / Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems](#)

AI001 / high / open

Dynamic Python code execution

```
agent.py:16
```

```
return eval(model_response)
```

Replace dynamic execution with an allowlisted operation dispatcher; use `ast.literal_eval` only for bounded literal parsing. Isolate unavoidable execution with no ambient credentials and strict resource limits.

Fix plan and agent/MCP relevance

Replace dynamic Python evaluation with a bounded operation interface.

Why this matters for agents/MCP: An agent can convert a prompt or MCP tool result into an eval/exec argument. If that value reaches this call, model influence becomes Python execution with the tool process identity.

Inspect the reported source location and its callers, change the implementation or effective configuration, then rebuild and rescan. The scan does not establish that this code is on an active agent or MCP request path.

Confirm applicability: Trace the expression from its producer to this exact call; a nonliteral expression alone does not establish external control or an active agent path.

Confirm applicability: Trusted fixed startup code and deliberately isolated code-execution services need different treatment; document which boundary applies.

1. Remove the interpreter boundary

Replace eval/exec with a dictionary of fixed callable operations and validate a small JSON argument schema before selecting a callable. Do not permit callers to name arbitrary modules, attributes or Python expressions.

Verify: Send unsupported operation names and extra arguments through the same tool entry point; verify rejection before any callable executes.



2. Choose a bounded data parser

For data, prefer JSON plus explicit type, length and nesting limits. Use `ast.literal_eval` only when Python literals are genuinely required, with independent input and resource bounds; it is not a general untrusted-input sandbox.

Verify: Exercise malformed, oversized and deeply nested values in an isolated test and confirm bounded failure without evaluating names or calls.

3. Isolate required generated execution

If code execution is the product feature, route it to a disposable worker with a separate identity, scoped workspace, no ambient credentials, bounded CPU/memory/time and denied-by-default egress.

Verify: Attempt a forbidden workspace read, network request and long-running task in a test worker; retain denials and verify cleanup.

Remaining validation: A permitted operation may still violate tenant or business policy; authorize target resources outside the model.

Remaining validation: Rescanning can confirm removal of a recognized expression, not sandbox strength or absence of alternate execution paths.

Related controls: EXEC-02

[REM-PY-AST / Python `ast.literal\_eval` security and resource limits](#)

[OWASP-AGENT-CS / AI Agent Security Cheat Sheet](#)

[JOINT-DEPLOY / Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems](#)

AI010 / high / open

Credential-like literal in source or configuration

`mcp.json:6`

[REDACTED: credential-related source evidence; inspect this location locally]

If real, revoke and rotate the credential, remove it from source and history, and load it from a secret manager or environment variable with least privilege.

Fix plan and agent/MCP relevance

Classify the detected credential, rotate real exposure and remove embedded values.

Why this matters for agents/MCP: A hardcoded model, gateway or downstream-tool key can grant access outside the intended agent session and tenant. Repository or image readers may obtain the credential independently of the agent approval path.

Inspect the reported source location and its callers, change the implementation or effective configuration, then rebuild and rescan. The scan does not establish that this code is on an active agent or MCP request path.

Confirm applicability: Determine whether the value is a real credential, a nonsecret identifier or deliberate test data without copying the value into tickets or model prompts.

Confirm applicability: The detector does not validate the credential with its provider and does not establish prior misuse.

1. Revoke or rotate confirmed live credentials

Identify the credential owner and permissions using secret-safe metadata. Revoke or rotate real exposed credentials with a staged application update and review provider audit records.

Verify: Verify the old credential is rejected and the replacement has only required model/tool scopes; retain redacted rotation evidence.

2. Remove literals from delivery artifacts

Replace the literal with a secret-manager lookup or runtime injection. Remove it from tracked files, distributed image layers and relevant build artifacts; coordinate any history rewrite with repository owners.

Verify: Rescan the source and every retained image layer, and check logs/build artifacts for the old credential through a protected secret-scanning workflow.

3. Limit future credential reach

Use separate per-service or per-tenant credentials where supported and restrict which tool workers receive them. Exclude local secret files from version control and build contexts.

Verify: Run a tool that does not need the credential and verify it cannot read it; confirm clean builds do not embed injected build secrets.

Remaining validation: Deleting source text does not invalidate a copied credential; rotation and access review remain necessary.

Remaining validation: Environment injection can still expose secrets through process inheritance or diagnostics.

Related controls: AUTH-05, DATA-01

[CISA-SECURE-BY-DESIGN / Shifting the Balance of Cybersecurity Risk: Principles and Approaches for Secure by Design Software](#)

[MCP-SECURITY / MCP Security Best Practices](#)

AI031 / high / open

Agent approval or sandbox safeguard explicitly bypassed



mcp.json:7

```
"autoApprove": ["*"]
```

Use bounded tool permissions and an isolated runtime; require deliberate approval for destructive, external, financial, or credential-bearing actions.

Fix plan and agent/MCP relevance

Restore task-bound execution permissions and meaningful approval boundaries.

Why this matters for agents/MCP: Disabling agent approval or sandbox safeguards lets model-driven actions inherit the full process authority. Prompt injection or a mistaken plan can then modify files, send data or invoke credentials without the intended review boundary.

Inspect the reported source location and its callers, change the implementation or effective configuration, then rebuild and rescan. The scan does not establish that this code is on an active agent or MCP request path.

Confirm applicability: Confirm the exact agent/runtime setting and the environment it affects; dedicated controlled evaluation environments may intentionally bypass prompts.

Confirm applicability: Approval dialogs alone do not create OS isolation, and a sandbox alone does not establish user consent for external effects.

1. Replace unrestricted mode with explicit permissions

Remove bypass flags and configure the agent runtime permitted tools, workspace roots and network destinations for the task. Keep privileged administration in a separate identity/session.

Verify: Attempt a tool outside the task allowlist and a workspace/egress escape; verify the enforcement layer denies it without relying on model compliance.

2. Bind approvals to concrete actions

Require deliberate approval for relevant destructive, external, credential-bearing or financial effects, displaying target and material arguments. Expire approvals and recheck changed arguments.

Verify: Test a denied action, replayed approval and target substitution after approval; verify no unapproved side effect occurs.

3. Enforce isolation independently

Run tool workers with limited OS credentials, mounts, resource budgets and network rights. Propagate reduced authority to subagents and connectors.

Verify: Launch a delegated task and confirm it cannot acquire broader permissions, read host secrets or exceed the configured runtime budget.

Remaining validation: Users may approve misleading actions and allowed operations may be composed harmfully; adversarial workflow tests and audit trails remain needed.

Related controls: AGT-01, AGT-02, MCP-09, SUP-05

[OWASP-AGENT-CS / AI Agent Security Cheat Sheet](#)

[MCP-TOOLS / MCP: Tools](#)

AI029 / high / open

Remote MCP URL uses plaintext HTTP

mcp.json:10

```
"url": "http://mcp.example.invalid/mcp"
```

Use HTTPS with certificate verification for remote MCP endpoints. Reserve plaintext HTTP for explicitly controlled local development or a documented protected transport.

Fix plan and agent/MCP relevance

Use verified HTTPS for remote MCP endpoints and inspect every transport hop.

Why this matters for agents/MCP: Remote MCP requests can contain access tokens, task context and tool output. Plain HTTP exposes those bytes and allows modification by parties able to observe or influence the network path.

Inspect the reported source location and its callers, change the implementation or effective configuration, then rebuild and rescan. The scan does not establish that this code is on an active agent or MCP request path.

Confirm applicability: Confirm that the address is actually remote and identify TLS termination, tunnels and any plaintext backend hop.

Confirm applicability: Controlled loopback development and documented protected transport have different exposure; a URL alone cannot prove the effective network protections.

1. Configure an HTTPS endpoint

Replace the nonloopback HTTP MCP URL with the approved HTTPS service URL and require certificate/hostname verification. Provision a private CA when needed.

Verify: Use the actual MCP client to reject a wrong-host or untrusted certificate and accept the approved endpoint.



2. Check proxy-to-backend protection

Inspect all hops after TLS termination and restrict any plaintext backend segment to an explicitly controlled boundary, or use TLS/mTLS between components.

Verify: Verify the deployment path, listeners and policy prevent an unauthorized peer from observing or reaching the backend segment.

3. Remove insecure fallback and redirects

Ensure client retries and redirects cannot downgrade to HTTP or send credentials to another origin. Update environment/configuration overrides alongside the launch manifest.

Verify: Make the secure test endpoint fail or redirect to HTTP and confirm the client does not transmit an authenticated plaintext request.

Remaining validation: TLS does not validate tool results or protect secrets deliberately sent to an untrusted MCP server.

Related controls: MCP-01

MCP-HTTP / MCP: Streamable HTTP transport

MCP-AUTH / MCP: Authorization

JOINT-DEPLOY / Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems

AI021 / medium / open

Container explicitly runs as root

Dockerfile:2

USER root

COPY . /app

Use a dedicated nonroot runtime user and minimal capabilities; verify the final build stage and deployment security context.

Fix plan and agent/MCP relevance

Use a dedicated nonroot runtime identity and verify effective permissions.

Why this matters for agents/MCP: An injected or overbroad agent/MCP tool action inherits the container process identity. Root can increase access to mounted data and the impact of an isolation failure, although container root is not automatically host root.

Inspect the reported source location and its callers, change the implementation or effective configuration, then rebuild and rescan. The scan does not establish that this code is on an active agent or MCP request path.

Confirm applicability: The finding concerns an explicit image/build default; deployment runAsUser, rootless runtimes and user namespaces may alter its effect.

Confirm applicability: Review the final selected build stage and actual running UID rather than assuming every build-stage root command runs in production.

1. Set the runtime user

Create a dedicated service account during build and select it with USER in the final runtime stage. In Kubernetes, configure runAsNonRoot and an appropriate numeric runAsUser where required.

Verify: Inspect the built image user and the running process UID under the actual deployment; test startup fails rather than silently switching to root.

2. Provision only required writable paths

Set ownership for explicit runtime/cache/workspace directories, avoid broad chmod permissions, and use a read-only root filesystem where compatible.

Verify: Run normal tool operations and verify they work only in approved writable directories; confirm system and other-tenant paths are denied.

3. Remove adjacent privilege paths

Drop unnecessary capabilities, disable privilege escalation and avoid host mounts/runtime sockets. Ensure an entrypoint does not restore privilege.

Verify: Inspect effective capabilities, mounts and deployment overrides and perform denied-access tests as the worker identity.

Remaining validation: Nonroot execution reduces authority but does not establish tenant isolation or eliminate kernel/runtime escapes.

Related controls: SUP-05

REM-K8S-PODS / Kubernetes Pod Security Standards

REM-DOCKER-SECURITY / Docker Engine security and daemon access

AI018 / medium / open

MCP package runner resolves an unpinned artifact

mcp.json:4

"command": "npm",



Pin an exact audited package version and lock or verify transitive artifacts. Prefer preinstalled verified tools in a controlled environment.

Fix plan and agent/MCP relevance

Pin MCP launch artifacts and make the effective installation reproducible.

Why this matters for agents/MCP: An MCP client often launches a package with its local user permissions and injected credentials. Unpinned npx/uvx resolution can replace the tool implementation between launches without a reviewed configuration change.

Inspect the reported source location and its callers, change the implementation or effective configuration, then rebuild and rescan. The scan does not establish that this code is on an active agent or MCP request path.

Confirm applicability: Inspect the actual package runner, registry and cache/lock behavior; a project lockfile may not govern an independent ephemeral runner.

Confirm applicability: An exact version reduces movement but does not prove package integrity or constrain all transitive dependencies.

1. Pin the selected package

For npm execution specify an exact package version, including scope where applicable; for uvx use an exact package version or explicit --from package==version. Keep the chosen package identity distinct from its executable name.

Verify: Start from a clean controlled cache and record the resolved package/version; verify the MCP launch command selects that exact artifact.

2. Verify the complete runtime artifact

Prefer a preinstalled tool built from a reviewed lockfile or verified artifact, with an approved registry and integrity data for dependencies. Audit additional --with packages and executable-search paths.

Verify: Compare fresh installations in controlled environments and investigate any dependency/artifact digest differences.

3. Limit launch credentials and updates

Run the server with only task-required credentials and workspace permissions. Propose version updates through review, provenance checks and regression tests rather than enabling automatic latest resolution.

Verify: Verify the launched process identity/environment and exercise a required tool after a reviewed update without expanding its permissions.

Remaining validation: Package cache isolation is not an operating-system sandbox; a pinned compromised package still executes with its granted authority.

Related controls: MCP-09, SUP-01

REM-UV-TOOLS / uv: tool versions and environments

REM-NPM-EXEC / npm exec: package selection and execution

MCP-SECURITY / MCP Security Best Practices

AI024 / low / open

Container image is not digest pinned

Dockerfile:1

FROM python:latest

Pin approved image digests, track provenance and SBOMs, and update through reviewed vulnerability-remediation workflows.

Fix plan and agent/MCP relevance

Pin the approved image content digest and maintain a reviewed update process.

Why this matters for agents/MCP: Agent/MCP deployments may execute a different tool stack when a mutable image tag moves. That changes the code holding credentials and enforcing tool policy without a matching application source change.

Inspect the reported source location and its callers, change the implementation or effective configuration, then rebuild and rescan. The scan does not establish that this code is on an active agent or MCP request path.

Confirm applicability: Inspect the image selected by the actual build/deployment and platform; tags may already be constrained by external admission policy.

Confirm applicability: Digest pinning controls content identity, not whether the pinned content is safe or current.

1. Record and pin the intended digest

Replace mutable base/deployment references with the approved registry image@sha256 digest, retaining a human-readable version where useful. Record the intended platform or multi-platform index.

Verify: Resolve the approved reference through the build/deployment system and verify the running image digest matches the recorded artifact/platform.



2. Review provenance and contents

Associate the digest with build provenance, an SBOM and a separate vulnerability scan; verify the publisher and build process before approving it.

Verify: Trace the selected digest to the expected build and verify the SBOM and vulnerability results apply to that exact artifact.

3. Update pins deliberately

Use automation to propose digest updates, rebuild and run agent/MCP regression and policy checks, then roll out the reviewed artifact.

Verify: Exercise rollback to a previously approved digest and confirm updates do not silently widen runtime permissions.

Remaining validation: A digest can preserve a vulnerable version indefinitely if updates are neglected; this scanner does not perform a CVE feed lookup.

Related controls: SUP-01, SUP-03

[REM-DOCKER-BUILD / Docker: pin base image versions](#)

[JOINT-DEPLOY / Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems](#)

AI001 / Enforce action policy outside the model

Proposed control; effectiveness has not been verified.

How it helps: Have an execution service allow only named operations, permitted argument values, and caller-owned target resources before invoking a tool.

Evidence to obtain: Exercise disallowed operations, additional arguments, cross-tenant identifiers, and direct calls that bypass the agent planner.

Remaining limit: Authorized operations can still be harmful when business constraints are incomplete; prompt instructions cannot enforce this boundary.

Related controls: AGT-01, AUTH-02, MCP-02

[MCP-TOOLS / MCP: Tools](#)

[OWASP-AGENT-CS / AI Agent Security Cheat Sheet](#)

AI001 / Isolate tool execution

Proposed control; effectiveness has not been verified.

How it helps: Run the risky tool in a separate, disposable identity with no host mounts, ambient credentials, or unnecessary outbound access.

Evidence to obtain: In a test environment, attempt reads outside the workspace, forbidden network connections, and resource exhaustion; retain policy and denial evidence.

Remaining limit: Isolation limits reachable assets; it does not make injected code trustworthy or rule out a runtime escape.

Related controls: EXEC-02, SUP-05, OPS-02

[JOINT-DEPLOY / Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems](#)

AI002 / Enforce action policy outside the model

Proposed control; effectiveness has not been verified.

How it helps: Have an execution service allow only named operations, permitted argument values, and caller-owned target resources before invoking a tool.

Evidence to obtain: Exercise disallowed operations, additional arguments, cross-tenant identifiers, and direct calls that bypass the agent planner.

Remaining limit: Authorized operations can still be harmful when business constraints are incomplete; prompt instructions cannot enforce this boundary.

Related controls: AGT-01, AUTH-02, MCP-02

[MCP-TOOLS / MCP: Tools](#)

[OWASP-AGENT-CS / AI Agent Security Cheat Sheet](#)

AI002 / Isolate tool execution

Proposed control; effectiveness has not been verified.

How it helps: Run the risky tool in a separate, disposable identity with no host mounts, ambient credentials, or unnecessary outbound access.

Evidence to obtain: In a test environment, attempt reads outside the workspace, forbidden network connections, and resource exhaustion; retain policy and denial evidence.

Remaining limit: Isolation limits reachable assets; it does not make injected code trustworthy or rule out a runtime escape.

Related controls: EXEC-02, SUP-05, OPS-02

[JOINT-DEPLOY / Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems](#)



AI003 / Enforce action policy outside the model

Proposed control; effectiveness has not been verified.

How it helps: Have an execution service allow only named operations, permitted argument values, and caller-owned target resources before invoking a tool.

Evidence to obtain: Exercise disallowed operations, additional arguments, cross-tenant identifiers, and direct calls that bypass the agent planner.

Remaining limit: Authorized operations can still be harmful when business constraints are incomplete; prompt instructions cannot enforce this boundary.

Related controls: AGT-01, AUTH-02, MCP-02

[MCP-TOOLS / MCP: Tools](#)

[OWASP-AGENT-CS / AI Agent Security Cheat Sheet](#)

AI003 / Isolate tool execution

Proposed control; effectiveness has not been verified.

How it helps: Run the risky tool in a separate, disposable identity with no host mounts, ambient credentials, or unnecessary outbound access.

Evidence to obtain: In a test environment, attempt reads outside the workspace, forbidden network connections, and resource exhaustion; retain policy and denial evidence.

Remaining limit: Isolation limits reachable assets; it does not make injected code trustworthy or rule out a runtime escape.

Related controls: EXEC-02, SUP-05, OPS-02

[JOINT-DEPLOY / Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems](#)

AI005 / Verify artifact identity before use

Proposed control; effectiveness has not been verified.

How it helps: Require reviewed artifact provenance plus a digest or signature checked against an independently trusted identity or manifest.

Evidence to obtain: Substitute bytes, producer identity, or verification metadata in a controlled test and confirm the consumer rejects the artifact.

Remaining limit: Authenticity establishes the producer and bytes; an approved producer can still ship vulnerable or malicious content.

Related controls: SUP-03, DATA-04

[OPENSSE-MODEL-SIGNING / Launch of Model Signing v1.0](#)

[SLSA-12 / Supply-chain Levels for Software Artifacts specification](#)

AI005 / Separate artifact conversion from production

Proposed control; effectiveness has not been verified.

How it helps: Perform necessary conversion of legacy serialized artifacts in a disposable environment without production data or credentials.

Evidence to obtain: Demonstrate that a conversion job cannot reach production services and only approved output formats are promoted.

Remaining limit: Conversion output still needs integrity, format, and downstream behavior review; isolation is not proof of benign content.

Related controls: EXEC-06, SUP-06

[JOINT-DEPLOY / Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems](#)

[TECH-PYTORCH-SERIAL / PyTorch Serialization semantics](#)

AI006 / Require authenticated encrypted transport

Proposed control; effectiveness has not been verified.

How it helps: Use verified TLS on every relevant network hop, with an appropriate public or private CA and validated service hostname.

Evidence to obtain: Present an untrusted, expired, or wrong-host certificate and verify rejection; inspect backend traffic after TLS termination.

Remaining limit: TLS does not protect data from an authorized endpoint, compromised gateway, or plaintext segments beyond termination.

Related controls: MCP-01, AUTH-05

[MCP-AUTH / MCP: Authorization](#)

[MCP-AUTH-SEC / MCP: Authorization Security Considerations](#)



AI006 / Restrict outbound destinations independently

Proposed control; effectiveness has not been verified.

How it helps: Enforce an outbound policy outside the application that permits only required destinations and services; include IPv6 and proxy paths.

Evidence to obtain: From the deployed identity, test direct IP, DNS, redirect, metadata-service, and proxy-mediated attempts to prohibited destinations.

Remaining limit: Allowed destinations may themselves accept leaked data; destination rules do not replace content and action authorization.

Related controls: EXEC-05, AGT-07, SUP-05

[JOINT-DEPLOY / Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems](#)

[MCP-SECURITY / MCP Security Best Practices](#)

AI010 / Investigate and contain confirmed secret exposure

Proposed control; effectiveness has not been verified.

How it helps: For a real exposed credential, identify reachable systems, revoke or rotate it, and review access records for misuse.

Evidence to obtain: Confirm the old credential no longer works and record the exposure window, affected copies, and follow-up owner.

Remaining limit: Successful rotation stops future use of that credential but cannot reverse access or data loss that already occurred.

Related controls: AUTH-05, OPS-06

[CISA-JCDC / JCDC AI Cybersecurity Collaboration Playbook and Fact Sheet \(release notice\)](#)

[NIST-SSDF / Secure Software Development Framework \(SSDF\) Version 1.1](#)

AI010 / Use managed credential injection and revocation

Proposed control; effectiveness has not been verified.

How it helps: Load secrets at runtime through an approved store or workload identity; keep them out of source, artifacts, and model context.

Evidence to obtain: Test rotation and revocation without disclosing values; inspect build layers and launch metadata for retained copies.

Remaining limit: Deleting a file or hiding a later image layer does not revoke a credential or erase copies already distributed.

Related controls: AUTH-05, DATA-01, DATA-06

[JOINT-AGENTIC / Careful adoption of agentic AI services](#)

[MCP-AUTH / MCP: Authorization](#)

AI010 / Limit credentials available to the workload

Proposed control; effectiveness has not been verified.

How it helps: Give this component a distinct identity and only the downstream scopes and lifetime needed for its approved operations.

Evidence to obtain: Use its runtime identity to attempt forbidden service operations, then revoke it and confirm subsequent access fails.

Remaining limit: A compromised component can still use its allowed permissions until credentials expire or revocation takes effect.

Related controls: AUTH-05, AUTH-09

[JOINT-AGENTIC / Careful adoption of agentic AI services](#)

AI029 / Require authenticated encrypted transport

Proposed control; effectiveness has not been verified.

How it helps: Use verified TLS on every relevant network hop, with an appropriate public or private CA and validated service hostname.

Evidence to obtain: Present an untrusted, expired, or wrong-host certificate and verify rejection; inspect backend traffic after TLS termination.

Remaining limit: TLS does not protect data from an authorized endpoint, compromised gateway, or plaintext segments beyond termination.

Related controls: MCP-01, AUTH-05

[MCP-AUTH / MCP: Authorization](#)

[MCP-AUTH-SEC / MCP: Authorization Security Considerations](#)

AI029 / Limit credentials available to the workload

Proposed control; effectiveness has not been verified.

How it helps: Give this component a distinct identity and only the downstream scopes and lifetime needed for its approved operations.

Evidence to obtain: Use its runtime identity to attempt forbidden service operations, then revoke it and confirm subsequent access fails.

Remaining limit: A compromised component can still use its allowed permissions until credentials expire or revocation takes effect.

Related controls: AUTH-05, AUTH-09

[JOINT-AGENTIC / Careful adoption of agentic AI services](#)



AI031 / Enforce action policy outside the model

Proposed control; effectiveness has not been verified.

How it helps: Have an execution service allow only named operations, permitted argument values, and caller-owned target resources before invoking a tool.

Evidence to obtain: Exercise disallowed operations, additional arguments, cross-tenant identifiers, and direct calls that bypass the agent planner.

Remaining limit: Authorized operations can still be harmful when business constraints are incomplete; prompt instructions cannot enforce this boundary.

Related controls: AGT-01, AUTH-02, MCP-02

[MCP-TOOLS / MCP: Tools](#)

[OWASP-AGENT-CS / AI Agent Security Cheat Sheet](#)

AI031 / Bind sensitive actions to explicit approval

Proposed control; effectiveness has not been verified.

How it helps: Require an independent approval for the exact actor, tool, normalized arguments, target, and expiry before irreversible effects occur.

Evidence to obtain: Change arguments after approval, replay the approval, and call after expiry; each attempt must be denied before a side effect.

Remaining limit: Approval cannot compensate for misleading previews, excessive approver authority, or actions that happen before the check.

Related controls: AGT-02, OPS-04

[OWASP-AGENT-CS / AI Agent Security Cheat Sheet](#)

AI031 / Isolate tool execution

Proposed control; effectiveness has not been verified.

How it helps: Run the risky tool in a separate, disposable identity with no host mounts, ambient credentials, or unnecessary outbound access.

Evidence to obtain: In a test environment, attempt reads outside the workspace, forbidden network connections, and resource exhaustion; retain policy and denial evidence.

Remaining limit: Isolation limits reachable assets; it does not make injected code trustworthy or rule out a runtime escape.

Related controls: EXEC-02, SUP-05, OPS-02

[JOINT-DEPLOY / Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems](#)

AI018 / Resolve and install reviewed dependency bytes

Proposed control; effectiveness has not been verified.

How it helps: Use a committed lock or approved artifact manifest, enforce it during installation, and retain the resolved dependency inventory.

Evidence to obtain: Build in a clean environment and compare resolved bytes; modify a lock or artifact and verify the release gate rejects it.

Remaining limit: An exact version or digest can still identify a vulnerable artifact; mutable transitive dependencies must also be constrained.

Related controls: SUP-01, SUP-03

[NIST-SSDF / Secure Software Development Framework \(SSDF\) Version 1.1](#)

[OPENSSEF-BASELINE-202608 / Open Source Project Security Baseline](#)

AI018 / Verify artifact identity before use

Proposed control; effectiveness has not been verified.

How it helps: Require reviewed artifact provenance plus a digest or signature checked against an independently trusted identity or manifest.

Evidence to obtain: Substitute bytes, producer identity, or verification metadata in a controlled test and confirm the consumer rejects the artifact.

Remaining limit: Authenticity establishes the producer and bytes; an approved producer can still ship vulnerable or malicious content.

Related controls: SUP-03, DATA-04

[OPENSSEF-MODEL-SIGNING / Launch of Model Signing v1.0](#)

[SLSA-12 / Supply-chain Levels for Software Artifacts specification](#)

AI018 / Limit credentials available to the workload

Proposed control; effectiveness has not been verified.

How it helps: Give this component a distinct identity and only the downstream scopes and lifetime needed for its approved operations.

Evidence to obtain: Use its runtime identity to attempt forbidden service operations, then revoke it and confirm subsequent access fails.

Remaining limit: A compromised component can still use its allowed permissions until credentials expire or revocation takes effect.

Related controls: AUTH-05, AUTH-09

[JOINT-AGENTIC / Careful adoption of agentic AI services](#)



AI021 / Apply runtime isolation controls together

Proposed control; effectiveness has not been verified.

How it helps: Use a dedicated nonroot identity, minimal capabilities, no privilege escalation, and an enforced syscall and mandatory-access policy where supported.

Evidence to obtain: Inspect the effective workload and attempt privileged operations, prohibited syscalls, and access to protected host resources.

Remaining limit: Nonroot alone is insufficient; writable mounts, added capabilities, host namespaces, and kernel flaws can weaken isolation.

Related controls: SUP-05, TEST-05

[CIS-CONTROLS-81 / CIS Critical Security Controls v8.1](#)

[JOINT-DEPLOY / Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems](#)

AI021 / Separate risky tools from sensitive workloads

Proposed control; effectiveness has not been verified.

How it helps: Place tools needing exceptional privileges in a separate environment with narrow interfaces and no unrelated tenant data.

Evidence to obtain: Test cross-workload network and filesystem access and confirm the privileged component cannot impersonate the requesting agent.

Remaining limit: Shared kernels or administrative infrastructure may retain common failure paths; a container is not automatically a strong hostile-code boundary.

Related controls: SUP-05, TEST-04, GOV-02

[CSA-CCM / Cloud Controls Matrix and CAIQ v4.1](#)

[JOINT-AGENTIC / Careful adoption of agentic AI services](#)

AI024 / Verify artifact identity before use

Proposed control; effectiveness has not been verified.

How it helps: Require reviewed artifact provenance plus a digest or signature checked against an independently trusted identity or manifest.

Evidence to obtain: Substitute bytes, producer identity, or verification metadata in a controlled test and confirm the consumer rejects the artifact.

Remaining limit: Authenticity establishes the producer and bytes; an approved producer can still ship vulnerable or malicious content.

Related controls: SUP-03, DATA-04

[OPENSSF-MODEL-SIGNING / Launch of Model Signing v1.0](#)

[SLSA-12 / Supply-chain Levels for Software Artifacts specification](#)

AI024 / Keep pinned artifacts maintained

Proposed control; effectiveness has not been verified.

How it helps: Review known-vulnerability and maintenance evidence for the actual resolved artifacts and apply updates through a repeatable release process.

Evidence to obtain: Demonstrate a dependency update, relevant regression checks, and deployment or rollback of the resulting approved artifact.

Remaining limit: This source/image scan does not provide a current CVE verdict, and a vulnerability database cannot identify every unknown flaw.

Related controls: SUP-02, SUP-04, OPS-05

[NIST-SSDF / Secure Software Development Framework \(SSDF\) Version 1.1](#)

[OPENSSF-SCORECARD / OpenSSF Scorecard](#)



Optional advisory review and evidence

Model interpretations are advisory. They do not dismiss static findings, prove control effectiveness or change deterministic evidence. A verified quotation proves its presence in the supplied excerpt, not the correctness of the interpretation.

Omissions, evidence collection limits, errors and budgets are recorded in the optional-review summary above. Proposed verification steps have not been executed by this scanner.

GOV-01 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

GOV-02 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

GOV-03 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

GOV-04 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

GOV-05 / Advisory check review: not_reviewed



Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

GOV-06 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

AUTH-01 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

AUTH-02 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

AUTH-03 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.



Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

AUTH-04 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

AUTH-05 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

AUTH-06 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

AUTH-07 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

AUTH-08 / Advisory check review: not_reviewed



Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

AUTH-09 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

MCP-01 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

MCP-02 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

MCP-03 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.



Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

MCP-04 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

MCP-05 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

MCP-06 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

MCP-07 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

MCP-08 / Advisory check review: not_reviewed



Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

MCP-09 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

MCP-10 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

AGT-01 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

AGT-02 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.



Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

AGT-03 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

AGT-04 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

AGT-05 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

AGT-06 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

AGT-07 / Advisory check review: not_reviewed



Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

EXEC-01 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

EXEC-02 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

EXEC-03 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

EXEC-04 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.



Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

EXEC-05 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

EXEC-06 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

EXEC-07 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

DATA-01 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

DATA-02 / Advisory check review: not_reviewed



Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

DATA-03 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

DATA-04 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

DATA-05 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

DATA-06 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.



Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

SUP-01 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

SUP-02 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

SUP-03 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

SUP-04 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

SUP-05 / Advisory check review: not_reviewed



Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

SUP-06 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

OPS-01 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

OPS-02 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

OPS-03 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.



Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

OPS-04 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

OPS-05 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

OPS-06 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

TEST-01 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

TEST-02 / Advisory check review: not_reviewed



Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

TEST-03 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

TEST-04 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

TEST-05 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

TEST-06 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.



Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

TEST-07 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

TEST-08 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

TEST-09 / Advisory check review: not_reviewed

Check 1 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.

Check 2 / insufficient_evidence

Control review was not started because finding triage or judge configuration failed.

No model assessment was received for this check.

Verification still required: Collect the required evidence and review this check with its responsible owner.



Coverage gaps and required validation

No operational gap was recorded within the selected scope. Unsupported runtime properties still require their own checks.



Interactive review workspace

Every bound item below remains tied to its original evidence. Blank means unreviewed. Any nonblank decision requires a reason; justified/disabled also require a reviewer. Coverage gaps cannot be justified or disabled. Runtime/human decisions identify outstanding validation and are not passes.

Long fields scroll in compatible PDF viewers. Save with regenerated appearances. If your editor flattens the form or cannot preserve it, use the JSON review workspace instead.

finding:979d192981c1785a2394fe19

finding

AI002 Dynamic command executed through a shell - agent.py:9

Evidence binding: 18f1fa5798453e2d846e3bdf8d0bc73e207e6a48155c7b9b99c4f17a2158e6f

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

finding:0fa7e450cd583d78646ef397

finding

AI003 Dynamic os shell command - agent.py:10

Evidence binding: 9640699000a7ba1eac1ba86126456f6201c7c03853b23d5f3454718cc55f0c71

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

**finding:07fc5f6fd7699fd0194dc479**

finding

AI006 TLS certificate verification disabled - agent.py:11

Evidence binding: 04afd8d9ed3908ec13dfab9c00854dd10405e1bcd5de253ec71ac538d0322b

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****finding:d2d09fb2875db72f18779bfc**

finding

AI005 Executable deserialization requires trusted inputs - agent.py:12

Evidence binding: 18fa4a5c4cb2cb5b4d1c8cdee11aa13d0cebddd1af1c2281f98e47a42aaa348c7

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**finding:b1b0f0a3f33fe93875fcb58a**

finding

AI001 Dynamic Python code execution - agent.py:16

Evidence binding: f42fa2af2e0f69ddaee4e29866720fe7b117f85fe0c26c393cc1f0424427ea75

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****finding:afb2bdb94696690028650faf**

finding

AI010 Credential-like literal in source or configuration - mcp.json:6

Evidence binding: 4c93b01e8e290a4802d5ff969d089ac0676489544c36e6e07f1ffe8dc0fb2926

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**finding:592fbfc9b7dab062dc97906c**

finding

AI031 Agent approval or sandbox safeguard explicitly bypassed - mcp.json:7

Evidence binding: cecd07f0c0134c2c7f693002f85413e02442332ea2ef06faaeacbe6ee1c75ca4

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****finding:d841174f55e032505f8136b9**

finding

AI029 Remote MCP URL uses plaintext HTTP - mcp.json:10

Evidence binding: 8e063824dd5daac130db1685bff47b0a1d48982eb5b67cb19038dfab681cda53

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**finding:20771a324af20de316ec34f9**

finding

AI021 Container explicitly runs as root - Dockerfile:2

Evidence binding: 66cae5bbd131da660808a9864a08a69684d51e1f109c97fff33dd97b3359eab4

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****finding:6b77081a826c4c6833edc47f**

finding

AI018 MCP package runner resolves an unpinned artifact - mcp.json:4

Evidence binding: ee0dc14ec4ab14eb2fdd60b08cf19c11a75fe807e9b85d74b7b1fca4fe95f46a

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**finding:055ed29e5f56926f1827a0b8**

finding

AI024 Container image is not digest pinned - Dockerfile:1

Evidence binding: a51f7ee8cd57f60aef6d8e524ae704a619518dec510c2f45ca50d3377c933541

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:GOV-01:1**

check

GOV-01:1 Record owner, deployment, model/version, MCP transport/version, exposed tools, data classes, and external endpoints.

Evidence binding: f6a3643abe18f47815dc145dc3917bf0bb204902e7fc9cc8213202377a1d3ba8

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:GOV-01:2**

check

GOV-01:2 Reconcile approved inventory with deployed configurations; investigate unregistered agents and servers.

Evidence binding: e317796f9a2732b8a09bde89a34756a049ab502f85f448a57d0c5dab2bdf247c

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:GOV-02:1**

check

GOV-02:1 Diagram user, model, memory, tool, server, gateway, and downstream service boundaries with their credentials.

Evidence binding: 2367479e150bf143cf926ff76493cf93435e894002ef8452e6a106b695602882

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:GOV-02:2**

check

GOV-02:2 Identify who controls each input and the highest-impact action reachable if that input is malicious.

Evidence binding: 368eda76c844b2a7ddf54dbe9712e7e7087750af8b455081197e42bcaa21108a

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:GOV-03:1**

check

GOV-03:1 Assign an owner to each autonomous action and document permitted purposes, forbidden outcomes, and escalation routes.

Evidence binding: 2aec6915d58be768b0980cf93bedb38270244354517ace014278cda3b3589e2a

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:GOV-03:2**

check

GOV-03:2 Record impact, reversibility, approval requirements, and accepted residual risk before production use.

Evidence binding: 100894c8d384dd0531c1cf8ed98f7029a459d03204ceaacac4a7a22f63bd90c8

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:GOV-04:1**

check

GOV-04:1 Give each control an owner, evidence link, validation date, result, and next review date.

Evidence binding: d584f2beaaa1bdf34364513877910ea9f522e7dee038b59ec95124b42d00fb83

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:GOV-04:2**

check

GOV-04:2 Time-limit exceptions and require a compensating control; distinguish untested behavior from demonstrated failure.

Evidence binding: 2ac2ac0903ae3df4fdc28b6b792a6818146f111e5e2555e629010c42f99a7e75

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:GOV-05:1**

check

GOV-05:1 Review security impact when adding a model, tool, server, data source, skill, or broader permission.

Evidence binding: 2949aab9292fb7c1f8c3a896b63acbabe0921adcaac6112b1ff84eb2a25aa264

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:GOV-05:2**

check

GOV-05:2 Require deployment evidence for the complete configured system; a model-only score is insufficient.

Evidence binding: 55602f834be85e4104f4471a2d7fa2a85e7210184a68589ed985ef1baf07da6e

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:GOV-06:1**

check

GOV-06:1 For each model, gateway, orchestrator, MCP service, and cloud provider, document which party implements each applicable safeguard and which customer configuration it depends on.

Evidence binding: a5ec1c39571f45768527a04452838d794697f045a0176f93830a16e989e2d3d6

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:GOV-06:2**

check

GOV-06:2 Obtain current supplier evidence for inherited safeguards, identify unowned gaps, and record reassessment triggers in the service review.

Evidence binding: fe28567530ea13443345edd2f4419f8eff71a34a4040989328853d694c2fcf57

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AUTH-01:1**

check

AUTH-01:1 Trace authentication to every protected HTTP entry point, including tool calls, subscriptions, and retries.

Evidence binding: 37b381f2c510e6f9fe38557a0401b6603af2e8a491c46decf933f8367141297c

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:AUTH-01:2**

check

AUTH-01:2 Verify missing, expired, revoked, or malformed credentials cannot invoke a protected operation.

Evidence binding: cb20a2499b59244f9146e062e76c66b99e91c39e3b212d4511968ccb634b213b

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AUTH-02:1**

check

AUTH-02:1 Check user/agent identity, tenant, tool, target object, and requested operation immediately before execution.

Evidence binding: 9d99907518e6c60decea4bfa85fc8e1bf467d2692e8f5bbe8cef12fe4715df91

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:AUTH-02:2**

check

AUTH-02:2 Deny by default; test read-only callers against write tools and object identifiers owned by another user.

Evidence binding: 623d05a2113dfbac538e1a6e013a8689fd16bfb4a75fe1ff95675cdadc34d993

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AUTH-03:1**

check

AUTH-03:1 Verify signature with trusted keys, allowed algorithms, expected issuer/audience, expiry, and required scopes.

Evidence binding: 652b96d6140a7bbb74c94c35ee584c8cb7205ceaada8fc241c65231e373f3558

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:AUTH-03:2**

check

AUTH-03:2 Reject unsigned tokens and tokens minted for another service; decoding a JWT alone is not validation.

Evidence binding: cad3d4ad10d448dcefa72ec25148133c98b70798af41572d89fa7d732bd86c04

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AUTH-04:1**

check

AUTH-04:1 Use audience-bound MCP credentials and separately authorized downstream credentials; never forward arbitrary caller tokens.

Evidence binding: 7a7b860554831cfdd36a80a5cb4a0bfedf7419063dd24e8505ad39cf42eea4bb

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:AUTH-04:2**

check

AUTH-04:2 Ensure a proxy cannot use its broader service identity to perform an action the caller cannot authorize.

Evidence binding: 2f2681b054fbc34a3859557c774bab666193bf41e3ab3f2cd27215b0ca1d8c3f

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AUTH-05:1**

check

AUTH-05:1 Use short-lived scoped credentials where supported, protect refresh tokens, and validate rotation and revocation.

Evidence binding: 1826ff3c1c17ad48d38d62be48ad77bf6afc8308e0b6e5258915fc2b931451dd

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:AUTH-05:2**

check

AUTH-05:2 Avoid tokens in query strings, model context, source, child-process arguments, and diagnostic output.

Evidence binding: fd3d49ae577178ca1b76f7b6238e8702bb91ee5e5c0d65cd2d2cb9fde3ef6472

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AUTH-06:1**

check

AUTH-06:1 Test PKCE support and S256, exact registered redirects, transaction binding, and authorization-response issuer validation.

Evidence binding: dca1356faad6c33ca8dbf2947c76aa9c38222c959f4e36eb69bddbb82226d956

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:AUTH-06:2**

check

AUTH-06:2 Reject replayed codes, mismatched issuers, unsafe redirect schemes, and unsolicited callback transactions.

Evidence binding: 4e37848dcade64261d548b1fe96ad4e69ef7f6a44da4e5cd5c53349cefe1d4d0

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AUTH-07:1**

check

AUTH-07:1 Validate discovered metadata and client metadata URLs before fetching; constrain schemes, destinations, redirects, and response sizes.

Evidence binding: 96c56570e7e9b12e4701c4211a566beb43ad7a060c0f70eba573ab90219e9365

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:AUTH-07:2**

check

AUTH-07:2 Document trust policy for client registration and prevent discovery from reaching internal metadata or privileged network services.

Evidence binding: 1d6c85d22dc8d43080c098fa5e1229ed7109717f580d5fd2c7d0a29e8f72e6c1

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AUTH-08:1**

check

AUTH-08:1 Carry authenticated initiator and delegation identity through multi-agent calls instead of trusting identity fields in text.

Evidence binding: 5286651654bcb7da4f5dc0749431d7915cd6730bac459ab750ee7f0bbf43bfcb

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:AUTH-08:2**

check

AUTH-08:2 Prevent agents from granting themselves privileges; limit delegation scope, depth, lifetime, and downstream audiences.

Evidence binding: be8c89bde29ce229329dd72a3aafb1a1b81cc6d7c8e92ad4843076c974d5e82f

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AUTH-09:1**

check

AUTH-09:1 Enroll agents under an accountable sponsor and approved workload identity; verify identity claims before issuing credentials or granting discovery and execution access.

Evidence binding: 0dfaf5ae2360297d1460bb6a10d93daf39694ad2c361d8bd3353954c12f75c76

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:AUTH-09:2**

check

AUTH-09:2 Test retirement, sponsor departure, redeployment, and identity compromise; remove stale credentials, cached grants, registrations, and downstream access.

Evidence binding: d5563f4fba77cd33dc97abbc56dfa6d39237c7fe40983c27d607531ecf04e0be

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:MCP-01:1**

check

MCP-01:1 For HTTP, reject invalid Origin values and verify local deployments bind only to intended interfaces.

Evidence binding: ef96ebcf96dc5c293d24ca080fa101d43f199f04e40f45babd5e0607c89dd5a3

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:MCP-01:2**

check

MCP-01:2 Use TLS for remote protected endpoints; test DNS rebinding and proxy/header behavior in deployment.

Evidence binding: 6784a4a99641de2d83cf8f52e1e112043dbf74652a586af30a6048738a4319db

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:MCP-02:1**

check

MCP-02:1 Apply schemas and semantic bounds before executing every tool; reject unknown properties where appropriate.

Evidence binding: 592ae83cd25affd6bea7c13b407e5f87b96fc6ca9a21241820cbc33703780825

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:MCP-02:2**

check

MCP-02:2 Bound sizes and nesting; validate declared structured output and render errors without leaking secrets.

Evidence binding: 91351da7a9860ce4afa0cb58dd77a1317e3fb884559d2ad69a67d9e8929049f7

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:MCP-03:1**

check

MCP-03:1 Inspect descriptions, schemas, resources, icons, and results for instructions that cross tool or user boundaries.

Evidence binding: 62eae80afd3678e88e958ac8eedc37664655c6683f61d88c9d5ccb4da0294dce

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:MCP-03:2**

check

MCP-03:2 Never let readOnlyHint, destructiveHint, or other server claims replace independent authorization and approval policy.

Evidence binding: 7ead0870bfe726739d543dc0f6509be2061f13d4685c3de8da38bb53567e2cde

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:MCP-04:1**

check

MCP-04:1 Bind tool approval to verified server identity and the reviewed tool definition or version.

Evidence binding: 78a5192f21bd5b085a907d81de2c1c0cd4ba008dd5bd8bdcf11fca431a9d7385

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:MCP-04:2**

check

MCP-04:2 Revalidate changes after reconnect/list updates; disambiguate collisions across servers without trusting display names.

Evidence binding: 9c51d5cf62949410a1d25828e0931150458ebafb94d343ecacfe8af1610099cd

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:MCP-05:1**

check

MCP-05:1 Authorize every state handle against its owner and tenant; enforce expiry, unpredictability, and replay boundaries.

Evidence binding: 80259690c226c9459a54f636e2f276bd5d210f45e401dc7ad086920f34c8a242

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:MCP-05:2**

check

MCP-05:2 For older sessionful protocol versions, test session hijacking and cross-user resumption; a session ID is not authentication.

Evidence binding: 45706d29e94d0cbecebf6f11d208a45a929662314e3043a6ed286435c390a38e

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:MCP-06:1**

check

MCP-06:1 Apply host policy and user control to sampling requests, context sharing, model selection, and associated tool access.

Evidence binding: c11dc0037a25b0452eadb396751cfdc0a13afacfc0218bf8d8860c3f9afd8584

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:MCP-06:2**

check

MCP-06:2 Test whether an untrusted server can induce disclosure from unrelated conversations or recursively consume model budget.

Evidence binding: 7612e172be148792402abbda7216ffbbe564b6ae2fb4d3625012699e6ebcc33d

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:MCP-07:1**

check

MCP-07:1 Keep sensitive credential collection out of form-mode elicitation; validate and visibly identify URL destinations.

Evidence binding: ff464c2cf9ee54d05e3065bf52711ea424e13c8890725badcf844beb7304376d

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:MCP-07:2**

check

MCP-07:2 Test cancellation, phishing URLs, unsolicited interactions, and replayed completion state against the selected protocol version.

Evidence binding: 040f5118b0b968c408716e566022d5f667088d68e24cbcf7fb3f9ae3cf451e8c

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:MCP-08:1**

check

MCP-08:1 Treat declared roots as scoped information, not an operating-system sandbox or complete authorization mechanism.

Evidence binding: 778dda4abfc68a54f32674d21f6242b8e17fd7633a9769e3a24de6af75423099

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:MCP-08:2**

check

MCP-08:2 Enforce allowed paths at file access and test traversal, symlinks, alternate encodings, and writes outside the workspace.

Evidence binding: 05fb9f7d546d1607048bc3edab06e0aa663137618efe36f3401f75786ee12a38

DECISION**REVIEWER****REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:MCP-09:1**

check

MCP-09:1 Approve executable and package identity before starting a stdio server; use argument arrays and a minimal environment.

Evidence binding: 08063e21075108cd959ed4b6da576d071f2b0ac8542c176c27f6998bfe04dd51

DECISION**REVIEWER****REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:MCP-09:2**

check

MCP-09:2 Restrict proxy process-spawn APIs and child filesystem/network permissions; separate stdout protocol traffic from logs.

Evidence binding: f3e7d79b25122c853eb241bdb9ccf758fc1b86a5caa3b9028dde5cea7a7f13f9

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:MCP-10:1**

check

MCP-10:1 Record supported revisions and test their capability, metadata, header consistency, stream, and cancellation rules.

Evidence binding: f2e96e76caafd7a7bf96167fa285814fb0a9d5df29231107232e3fabb7c3216b

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:MCP-10:2**

check

MCP-10:2 Prevent caches and request continuations from crossing authorization contexts; do not apply legacy handshake assumptions universally.

Evidence binding: 7b452d521f9ee0f7e1293078b8594af1d1c6ca77975defd561771da9dda45b45

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AGT-01:1**

check

AGT-01:1 Place allow/deny decisions at the execution boundary using trusted policy inputs and constrained tool capabilities.

Evidence binding: fdd7f279674b5f55810fd01fbfbc96072e1fc6c3f7fae464b5fe0ac9a4392622

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:AGT-01:2**

check

AGT-01:2 Show that an injected instruction cannot disable policy, choose privileged credentials, or bypass approval.

Evidence binding: 0b0ec5dde2c7a8625c86b02f57a9c5f59f75da3f9987d91510616284446d6d4e

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AGT-02:1**

check

AGT-02:1 Present actual recipient, target, arguments, data disclosure, and consequences for high-impact approval.

Evidence binding: 50c0fba9f81e66a5211942df8bcc09ca22e06bf55877f7c1070f005c989d21c3

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:AGT-02:2**

check

AGT-02:2 Invalidate approval if arguments or target change; test races, delayed retries, and approval reuse.

Evidence binding: a033289bf0decaa47d3cf02dd423685f55011d698a08c5d7dea90d1bbeecf4cb

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AGT-03:1**

check

AGT-03:1 Track origin and trust level for web pages, documents, messages, OCR, tool results, and repository instructions.

Evidence binding: 3694aae1d2c1a53d78df03733dbe73139445ae4e28e6c29131d29b8ebee3888f

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:AGT-03:2**

check

AGT-03:2 Test direct and indirect goal hijacking; formatting delimiters and prompt warnings alone are not access controls.

Evidence binding: aa328d7ce19c1c7bf1e21a7986023e44ddb2264e97dc47f2610949e4ea65cc49

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AGT-04:1**

check

AGT-04:1 Enforce document and memory ACLs at retrieval and update time, including vector search metadata filters.

Evidence binding: d9a65b0964b4a4b2520418a945349ec7826ba333b201fa0479c55582eef75864

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:AGT-04:2**

check

AGT-04:2 Test poisoned memory persistence, cross-tenant retrieval, provenance loss, deletion, and stale privileged context.

Evidence binding: 6d8292e9ae63443a27cb272554ed789857435676667705dc72f2ac253a9a5dd3

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AGT-05:1**

check

AGT-05:1 Constrain delegated tasks and verify messages against authenticated senders, expected schemas, and allowed transitions.

Evidence binding: c9694e0f44191da1fc971c978826d6965acd1f559d787b504cdb2983e6a41871

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**



check:AGT-05:2

check

AGT-05:2 Test impersonation, conflicting instructions, cascading failure, and privilege growth across handoffs.

Evidence binding: 36fc882a773a28de1736889c3fa8e13f83ee0705fabe8151511c5f1ef3d7e161

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

check:AGT-06:1

check

AGT-06:1 Inventory skill files, prompts, hooks, memory seed files, MCP configuration, and other executable workflow inputs.

Evidence binding: 459c725f7c341d1cc4f07544e0666b06e31a41ae0a5cbb52303b2494fc681382

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

**check:AGT-06:2**

check

AGT-06:2 Require review for changes that add commands, access, or persistence; external repository text cannot become trusted policy.

Evidence binding: da2872a59d34ab7462d72e77a2e5c7ee9d3ffd593442dee72cc65044c5d44898

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:AGT-07:1**

check

AGT-07:1 Apply destination and data policies to URLs, searches, tickets, messages, uploads, and telemetry generated by agents.

Evidence binding: 7ccd26e6d6e78edfdc5c3fc004f9f9e2bc52e9dc8769ccb4b7acf882debd8086

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:AGT-07:2**

check

AGT-07:2 Use canary data to test encoded leakage and combinations of otherwise permitted tools.

Evidence binding: 5280e9deb7cbd42e68849631ca600b0b7918c020ae54d9c53bee784f4c8463ca

DECISION**REVIEWER****REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:EXEC-01:1**

check

EXEC-01:1 Find shell execution and constructed command strings; use fixed executables, argument arrays, and allowed argument values.

Evidence binding: 748252c7c5de84fcc342f7cf6abc3cf17630f576ca218d5a71fb5b28e66e44a

DECISION**REVIEWER****REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:EXEC-01:2**

check

EXEC-01:2 Test untrusted tool inputs containing shell syntax, option injection, command substitution, and hostile filenames.

Evidence binding: bcc19b097b6e4795b9d87fb01fa66b066adb808c3b5245ec2afcad90ab9bc413

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:EXEC-02:1**

check

EXEC-02:1 Locate eval, exec, dynamic imports, templates, notebooks, and interpreter tools accepting model or user content.

Evidence binding: e708b0fa1c1ee6c7886cc324fe2f9f44ebececb80adc06790c04ffb80895a341

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:EXEC-02:2**

check

EXEC-02:2 Run required code execution in a disposable restricted environment with explicit filesystem, network, CPU, and time limits.

Evidence binding: bdedacd9af717506e4c066cd61850a6bf0290a6e7cb5428ab012a119bc9c3db7

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:EXEC-03:1**

check

EXEC-03:1 Use bound query parameters and allowed query shapes; inspect SQL, NoSQL, graph, and search-language construction.

Evidence binding: 6f43fc7f5288013383d9ba8986c2cb4922256f3d3b29a457336d1f390a396ad

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:EXEC-03:2**

check

EXEC-03:2 Separate read/write database identities and test whether generated queries can escape permitted objects or operations.

Evidence binding: e93e59031043d939c04abc8ec71070baa9c219a25a4538d4dd9d857a433c2063

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:EXEC-04:1**

check

EXEC-04:1 Resolve and enforce allowed paths at access time; constrain uploads, downloads, extraction, temporary files, and permissions.

Evidence binding: c254897b606e90a4ab81813578fd3581d73f98862a2f0b50fbf37ae33dfbada9

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:EXEC-04:2**

check

EXEC-04:2 Test symlink races, archive traversal, absolute paths, overwrite attempts, and secret-directory reads.

Evidence binding: f9821d26e1be5a7d479b0e9b9fe0d2d6392ee18bc4ae0238647d96a2b6d9cd36

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:EXEC-05:1**

check

EXEC-05:1 Restrict destinations and schemes at connection time; revalidate DNS resolution and each redirect.

Evidence binding: a7d440b28567e5f3ae7ce0f4d2c89cc428cf5a5e75d4525d666aac4f9d5c4bea

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:EXEC-05:2**

check

EXEC-05:2 Test loopback, private/link-local IPv4 and IPv6, cloud metadata, alternate encodings, and redirect-to-private cases.

Evidence binding: 46bbfaed7947f05f8dc9089d3362aee1ea514f3f8909e940ffd10dccbadf2bf2

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:EXEC-06:1**

check

EXEC-06:1 Inspect pickle, unsafe YAML, object deserialization, XML entity expansion, and unconstrained recursive parsers.

Evidence binding: 5e4bae567a6502af0818497f8e75844c06a2c40f63f9c1134d81c4702e883966

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:EXEC-06:2**

check

EXEC-06:2 Use data-only formats with byte, nesting, and type limits; test malformed input and expansion attacks.

Evidence binding: 3a4afd7e92bf09ae2c52df9a12fb2ebaf2d29a993af4744c3dc13a6986e5606a

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:EXEC-07:1**

check

EXEC-07:1 Use context-specific escaping for HTML/Markdown, avoid unsafe DOM sinks, and validate links and embedded media.

Evidence binding: 3aa65b09c03449a7e33c9b43e4c8f93c2f3649c6a0fe3477d322c17464726d33

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:EXEC-07:2**

check

EXEC-07:2 Test active SVG/HTML, malicious URLs, terminal escapes, and spreadsheet formulas in exported reports.

Evidence binding: 018358808b7c3b30bb22f14d3650f7c244258143c5f042897663a60f7d35179f

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:DATA-01:1**

check

DATA-01:1 Inspect code, examples, configuration, notebooks, test fixtures, and generated artifacts for secret-like values.

Evidence binding: 06ca4af74dd55d15717fd32b73793ea4eba83889f8193010dcc86d4e6384ae87

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:DATA-01:2**

check

DATA-01:2 Verify actual exposures with the owner, rotate real credentials, and remove them from reachable history and artifacts.

Evidence binding: 50b747cee4c9bcf4eb046e2c0bece3335d757dc82c61374e5d5e5356cc1558f1

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:DATA-02:1**

check

DATA-02:1 Map which prompts, tool outputs, memory, and code leave the environment and identify the receiving provider/gateway.

Evidence binding: 0b83b380d7936dc0c9a84f2f5f0f2112a2ab282f7a33a026884aff14abcb8f4

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:DATA-02:2**

check

DATA-02:2 Document allowed data classes, processing location, retention, and training use; redact before transmission where required.

Evidence binding: 1c827af6950f896a43f2e4d657d3d55ed8e81171ec7ceb7ec5f5ae7c63455b22

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:DATA-03:1**

check

DATA-03:1 Redact secrets and sensitive payloads before logs, traces, exception strings, and dashboards persist them.

Evidence binding: f9ad33c1610f40288e134c47684ec0652884abbff6114a1367b3e77c908a06ab

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:DATA-03:2**

check

DATA-03:2 Test the failure paths and provider errors as well as success paths; restrict access and export destinations.

Evidence binding: 7b15c09b541fd9132e0dd0b565fcc814686efb2c2a89ebb75cd5b8eb9074ae2c

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:DATA-04:1**

check

DATA-04:1 Record source, owner, version, transformation history, and integrity evidence for datasets, retrieval corpora, and memory seeds.

Evidence binding: 6810b0bda52aae3c7de919c64065c95f86eddc8526c6f996dc4a0d2e5e957ad9

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:DATA-04:2**

check

DATA-04:2 Quarantine unexpected changes and test how poisoned or stale data is detected, removed, and replaced.

Evidence binding: b0184b827f1297616c18573afd97cf9fdb0e29373c07cff3971ac9ddb0815e0

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:DATA-05:1**

check

DATA-05:1 Apply expiry and deletion to prompts, embeddings, caches, memory, tool artifacts, backups, and provider-held data.

Evidence binding: 63a6cccc1b8e75442f7c49ab080b32ca926b3c9aba61e109156201d3a72e9b7b

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:DATA-05:2**

check

DATA-05:2 Verify deleting a source record removes or invalidates dependent retrieval content and access grants.

Evidence binding: b42da36760680be315b0512e8ec82c590706628c8da9f6428047af388a2070d7

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:DATA-06:1**

check

DATA-06:1 Check transport verification, storage access controls, encryption settings, key separation, and backup permissions.

Evidence binding: fa363630ba43c44dceb65b509c2e7068d130766566461a0f5137f4dfcec3e459

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:DATA-06:2**

check

DATA-06:2 Validate key rotation and denied access using a principal outside the authorized tenant or operational role.

Evidence binding: f6c505f3b6e994aa0da8bb1e24af30f40cf12398823e37d2dda9c7cdd48115a6

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:SUP-01:1**

check

SUP-01:1 Review lockfiles and exact versions or immutable digests for packages, images, MCP servers, models, and plugins.

Evidence binding: ae3614c84482a4caf8d121758cccfecbce85cd4f36c6fa18a1ec8a13eb4c1041

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:SUP-01:2**

check

SUP-01:2 Flag runtime installs, floating tags, remote scripts, and dependency sources outside approved registries.

Evidence binding: 07ec72c8407fca29a62a67c9ca5e37bf2c7ebd36e7aa587288b87a414fc1ebb9

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:SUP-02:1**

check

SUP-02:1 Run appropriate package/container advisory tools against resolved dependencies and save database date and tool version.

Evidence binding: 03ac7d319f696a434e04289b93383016cff90dd915903bb9f3f9e324cb899595

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:SUP-02:2**

check

SUP-02:2 Triage reachability, fix availability, support status, and transitive dependencies; source pattern scans do not establish CVE coverage.

Evidence binding: e2f32d838f4c530915380e7a0207ef3c36aa681775bfef581c4c19bd8038d25d

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:SUP-03:1**

check

SUP-03:1 Verify publisher identity, hashes/signatures, build provenance, and intended origin before enabling artifacts.

Evidence binding: 1b79229a537075f83e0da26a11fe1d08b2359b4ae4ae6e0378fd684b9b3d4b52

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:SUP-03:2**

check

SUP-03:2 Review model loading and serialization behavior; an integrity hash cannot make an untrusted publisher safe.

Evidence binding: f00b36235b3209b14d0fd701ff1a8c46de02ad0124b7bb52a2c55acb531c2d72

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:SUP-04:1**

check

SUP-04:1 Restrict CI credentials and workflow permissions; review actions, build scripts, and release provenance.

Evidence binding: c0b01e58a0a30319956be6ae1dbb2faa7dcf03d2bec6400bd519fdb6d95a63a6

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:SUP-04:2**

check

SUP-04:2 Prevent untrusted contributions from executing with deployment secrets or changing approved agent policies.

Evidence binding: d10805f1729e1255cb0b9809c20a3abc99d76a1854f0f0f0198e475ce5813c

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:SUP-05:1**

check

SUP-05:1 Review root/privileged containers, host mounts, Docker sockets, unrestricted egress, debug mode, and public management endpoints.

Evidence binding: 93aaa21160aabf0569b1c0100fdad14a2fe4e57bd48e0e9324371af23120c810

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:SUP-05:2**

check

SUP-05:2 Separate agent execution from control-plane credentials and audit storage; test isolation in the deployed environment.

Evidence binding: e20deb392512e4e56cf47a3ea75e6533faf2c6bb0391e9c87d79f83db19cd298

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:SUP-06:1**

check

SUP-06:1 When training or fine-tuning, isolate development, evaluation, and production identities, data access, registries, and release permissions.

Evidence binding: 57801b39893ee7b3f425f00b9385768e4e1d3be1d57d5367fac1c5ca4e214580

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:SUP-06:2**

check

SUP-06:2 Protect datasets, weights, adapters, and configuration separately; monitor modifications and demonstrate that an untrusted training job cannot replace an approved production artifact.

Evidence binding: fe4b9cff5d1b2f8491386fc9c1dc1c7ec4204234291a1e1d0c2efe63736533

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:OPS-01:1**

check

OPS-01:1 Record initiating identity, delegated identity, tool/server/version, approved arguments, decision, outcome, and correlation identifiers.

Evidence binding: 8129f9f52de1eb06c616d98e03f1c0a0f1a053d3841ef7845b8413e47a2c13b8

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:OPS-01:2**

check

OPS-01:2 Protect log integrity and clock consistency; ensure agents cannot erase their own action history.

Evidence binding: 929facc50148a0f7041468e419a582764e9e4a355efb9a3a816056bfb96404eb

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:OPS-02:1**

check

OPS-02:1 Set server-enforced limits for iterations, tokens, tool calls, recursion, parallelism, bytes, cost, and elapsed time.

Evidence binding: 122760eb99465a59c26b029c5f12675f384ec9bf0887f1b4b6ebd3aa91b98639

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:OPS-02:2**

check

OPS-02:2 Exercise stuck loops and amplification paths; verify limits apply across retries and child agents.

Evidence binding: 58951162858aee96ddb14d88109ed77f5967ff7cc620ded6afcf28c0d16b0ab2

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:OPS-03:1**

check

OPS-03:1 Provide a tested stop mechanism that revokes work, credentials, queued actions, and child tasks.

Evidence binding: ad2c8d5b4a126859024c6f6d70cfba1843584aa1cdd88c8e482e17d2d1336b75

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:OPS-03:2**

check

OPS-03:2 Measure stop latency and verify cancelled or disconnected requests cannot later commit prohibited side effects.

Evidence binding: c4b6ed77ff59d06aaec1d8fd7f4349b5eff6be7b9abd04cec263ef099ce3d1da

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:OPS-04:1**

check

OPS-04:1 Deny or escalate when policy, identity, or approval checks fail; prevent fallback paths from widening privilege.

Evidence binding: d884152659d9b3a496ac2c544f09f2cb368dd50b9837c9ea1a2b1d69ff0ed0e5

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:OPS-04:2**

check

OPS-04:2 Test outages, partial failures, timeouts, retries, idempotency, and recovery of transactions with external effects.

Evidence binding: 10ceb58552bde6238796266f956ce58e45fe795410a91a449b4084d164a27514

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:OPS-05:1**

check

OPS-05:1 Alert on unusual tool use, new destinations, scope growth, repeated denials, cost spikes, and unexpected state changes.

Evidence binding: 8796ed55d368dad33fd86e93b33b99eb7672bf12680536700f571fdbf9e15ea8

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:OPS-05:2**

check

OPS-05:2 Validate alerts with seeded events and test rollback of models, prompts, tools, policies, and poisoned memory.

Evidence binding: 7e53026b9ea410f4cdf10690bd578dae60fed4895793f7f1a7ee1d531e2a8147

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:OPS-06:1**

check

OPS-06:1 Maintain procedures to isolate agents, revoke credentials, preserve evidence, notify owners, and recover trusted state.

Evidence binding: d742f8d7abeec21d740eb71d69f7530b97ce4f9581eec93bd6e263cbc2a793ee

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:OPS-06:2**

check

OPS-06:2 Exercise an AI-specific incident and define approved vulnerability/intelligence-sharing channels without exposing sensitive evidence.

Evidence binding: e24b985cdc28276fbe86ff4acfe584847257ce5617d9c0644b9399cc81a3512c

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:TEST-01:1**

check

TEST-01:1 Run paired benign and adversarial workflows with representative tools and attacker-controlled external content.

Evidence binding: aa18ec98a71cfe795661cb69d7121b9a37775bf524832518a4b51e7b219933d

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:TEST-01:2**

check

TEST-01:2 Record attacker success, authorized task success, blocked benign actions, and the observed unauthorized side effect.

Evidence binding: 68e86b429c5f071aafe3eac565f4ee8214b527affb79f61b6ad4e6ebd882f9f1

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:TEST-02:1**

check

TEST-02:1 Vary payload wording, placement, modality, attacker knowledge, and attempts; rerun after changing defenses.

Evidence binding: bf764da8d89e32342a635819f05d34ec395dcac89451c4eebcc0d276a415b1f5

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:TEST-02:2**

check

TEST-02:2 Report per-scenario outcomes, sample counts, attack budget, uncertainty, and model/harness versions instead of only an average.

Evidence binding: 92f390a0b0e770e7409fb747164149dfb0627faff7a6802456983990b6c61e08

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:TEST-03:1**

check

TEST-03:1 In an isolated test environment, exercise invalid tokens, wrong audiences, origin abuse, malicious servers, and protocol fuzzing.

Evidence binding: 4b3be909731e83ab58581ed721c03edf85d2ee36075af7da699f4f40ba6e73b2

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:TEST-03:2**

check

TEST-03:2 Adapt scenarios to the deployed MCP revision and transports; preserve request/response evidence with secrets removed.

Evidence binding: 09d1848c75a291dcc5607679169b18a4421f6999e0c991bfa33cbf5f0a8c4a25

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:TEST-04:1**

check

TEST-04:1 Create two principals and attempt cross-access to objects, memory, caches, handles, subscriptions, and execution results.

Evidence binding: 450e2d885c172fe7a6f2296e850a665df0e147e34b0494940ea7d3a1661afe83

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:TEST-04:2**

check

TEST-04:2 Repeat after reconnect, delegation, failed authentication, concurrent requests, and privilege revocation.

Evidence binding: 26efe2261b1f172310b8015317e2e5a37e41691f39e21875469365f7f663310a

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:TEST-05:1**

check

TEST-05:1 Use explicit forbidden-action canaries to verify enforcement survives hostile content, tool substitution, and delayed execution.

Evidence binding: 4580b4a3978ca37059ad506ea98e5591a3aeb18e16a0196816aaa0b3dfc74e17

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:TEST-05:2**

check

TEST-05:2 Confirm paths through retries, fallback models, alternate tools, and child agents enforce the same boundary.

Evidence binding: 0fd65d2e620dd143417cdc499f34148719480cc349b215fd07e2f7aa66ec7c50

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:TEST-06:1**

check

TEST-06:1 Run language-aware SAST, dependency review, secret scanning, and authorized integration tests for exposed services.

Evidence binding: 691dd8e8b071e292fab096b610cdd9a1d42f115af4918521e40dcaccede6b044

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:TEST-06:2**

check

TEST-06:2 Exercise reachable injection, XSS, SSRF, path traversal, deserialization, and access-control risks with safe fixtures.

Evidence binding: fa5139b80aa204928eeb4483db7e0c19d943f1140583aef2d8917016dd280c12

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:TEST-07:1**

check

TEST-07:1 Simulate oversized messages, slow peers, streaming floods, repeated errors, runaway agents, and unavailable dependencies.

Evidence binding: b05f93cbe1797a75b32c733f6d827bffab42a8a02475fa04a11155fd24a1053b

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:TEST-07:2**

check

TEST-07:2 Verify quotas, shutdown, telemetry, and alerts work together without leaking payloads or losing attribution.

Evidence binding: 9a340d9997faaf3639260fb081320b7112e12c09c8cb5c93dcdb40f5f3d1052a

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:TEST-08:1**

check

TEST-08:1 Treat repository text and model verdicts as untrusted; test prompt injection, fabricated locations, invalid JSON, and timeouts.

Evidence binding: 630e7762b29377c89dd7cf19ef63489378c89b103489785930f3408f935047d0

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**check:TEST-08:2**

check

TEST-08:2 Compare against labeled cases, retain deterministic results, document model variability, and never equate a judge approval with control validation.

Evidence binding: a14660a8dab7b5d918d6d632c04a25cf5d947a3a6d3cbffb0dda5600e11ac68a

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****check:TEST-09:1**

check

TEST-09:1 Where applicable, assess suspicious triggers, model extraction, and disclosure of private training examples under an explicit attacker access and query budget.

Evidence binding: 4353cd7a7563d21919b165d7e06c0c83b9bcb795fd2cde8a29cd8392a050d946

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**



check:TEST-09:2

check

TEST-09:2 Retest acquired or retrained models and adapters before release; document measured failures, model identity, coverage limits, and accepted residual risk.

Evidence binding: 7f4480ff912210f658e5df351610cb8e3b941eb86f375ddeb1a26aacad484d25

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE



Control checklist and evidence requirements

GOV-01 / Inventory every agent, MCP server, tool, and model

Scanner status: manual_review_required | validation: manual

1. Record owner, deployment, model/version, MCP transport/version, exposed tools, data classes, and external endpoints.
2. Reconcile approved inventory with deployed configurations; investigate unregistered agents and servers.

<https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-ai-rmf-10>

GOV-02 / Model trust boundaries and attack paths

Scanner status: manual_review_required | validation: manual

1. Diagram user, model, memory, tool, server, gateway, and downstream service boundaries with their credentials.
2. Identify who controls each input and the highest-impact action reachable if that input is malicious.

<https://github.com/mitre-atlas/atlas-data>

<https://csrc.nist.gov/pubs/ai/100/2/e2025/final>

GOV-03 / Define authorized use and accountable owners

Scanner status: manual_review_required | validation: manual

1. Assign an owner to each autonomous action and document permitted purposes, forbidden outcomes, and escalation routes.
2. Record impact, reversibility, approval requirements, and accepted residual risk before production use.

<https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-ai-rmf-10>

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/careful-adoption-o...>

GOV-04 / Maintain evidence and risk exceptions

Scanner status: manual_review_required | validation: manual

1. Give each control an owner, evidence link, validation date, result, and next review date.
2. Time-limit exceptions and require a compensating control; distinguish untested behavior from demonstrated failure.

<https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf>

<https://csrc.nist.gov/pubs/sp/800/218/final>

GOV-05 / Reassess changes in autonomy and integrations

Scanner status: manual_review_required | validation: manual

1. Review security impact when adding a model, tool, server, data source, skill, or broader permission.
2. Require deployment evidence for the complete configured system; a model-only score is insufficient.

<https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development>

GOV-06 / Assign shared security responsibilities across AI providers

Scanner status: manual_review_required | validation: manual

1. For each model, gateway, orchestrator, MCP service, and cloud provider, document which party implements each applicable safeguard and which customer configuration it depends on.
2. Obtain current supplier evidence for inherited safeguards, identify unowned gaps, and record reassessment triggers in the service review.

<https://cloudsecurityalliance.org/artifacts/ai-controls-matrix-v1-1>

<https://cloudsecurityalliance.org/artifacts/cloud-controls-matrix-v4-1>

AUTH-01 / Authenticate protected operations on every request

Scanner status: no_pattern_detected | validation: hybrid

1. Trace authentication to every protected HTTP entry point, including tool calls, subscriptions, and retries.
2. Verify missing, expired, revoked, or malformed credentials cannot invoke a protected operation.

<https://modelcontextprotocol.io/specification/2026-07-28/basic/authorization>



AUTH-02 / Authorize the exact action and target

Scanner status: no_pattern_detected | validation: hybrid

1. Check user/agent identity, tenant, tool, target object, and requested operation immediately before execution.
2. Deny by default; test read-only callers against write tools and object identifiers owned by another user.

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/careful-adoption-o...>

<https://modelcontextprotocol.io/specification/2026-07-28/server/tools>

AUTH-03 / Validate access-token cryptography and claims

Scanner status: no_pattern_detected | validation: hybrid

1. Verify signature with trusted keys, allowed algorithms, expected issuer/audience, expiry, and required scopes.
2. Reject unsigned tokens and tokens minted for another service; decoding a JWT alone is not validation.

<https://modelcontextprotocol.io/specification/2026-07-28/basic/authorization/security-considerations>

AUTH-04 / Prevent token passthrough and confused deputy use

Scanner status: no_pattern_detected | validation: hybrid

1. Use audience-bound MCP credentials and separately authorized downstream credentials; never forward arbitrary caller tokens.
2. Ensure a proxy cannot use its broader service identity to perform an action the caller cannot authorize.

<https://modelcontextprotocol.io/specification/2026-07-28/basic/authorization>

https://modelcontextprotocol.io/docs/2026-07-28/tutorials/security/security_best_practices

AUTH-05 / Constrain credential lifetime and exposure

Scanner status: findings_detected | validation: hybrid

1. Use short-lived scoped credentials where supported, protect refresh tokens, and validate rotation and revocation.
2. Avoid tokens in query strings, model context, source, child-process arguments, and diagnostic output.

<https://modelcontextprotocol.io/specification/2026-07-28/basic/authorization/security-considerations>

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/deploying-ai-syste...>

AUTH-06 / Bind OAuth flows and validate redirects

Scanner status: no_pattern_detected | validation: hybrid

1. Test PKCE support and S256, exact registered redirects, transaction binding, and authorization-response issuer validation.
2. Reject replayed codes, mismatched issuers, unsafe redirect schemes, and unsolicited callback transactions.

<https://modelcontextprotocol.io/specification/2026-07-28/basic/authorization/security-considerations>

<https://modelcontextprotocol.io/specification/2026-07-28/basic/authorization>

AUTH-07 / Secure OAuth discovery and registration

Scanner status: review_required | validation: hybrid

1. Validate discovered metadata and client metadata URLs before fetching; constrain schemes, destinations, redirects, and response sizes.
2. Document trust policy for client registration and prevent discovery from reaching internal metadata or privileged network services.

https://modelcontextprotocol.io/docs/2026-07-28/tutorials/security/security_best_practices

AUTH-08 / Bind delegation to identity, scope, and expiry

Scanner status: review_required | validation: hybrid

1. Carry authenticated initiator and delegation identity through multi-agent calls instead of trusting identity fields in text.
2. Prevent agents from granting themselves privileges; limit delegation scope, depth, lifetime, and downstream audiences.

https://cheatsheetseries.owasp.org/cheatsheets/AI_Agent_Security_Cheat_Sheet.html



AUTH-09 / Manage agent identity enrollment and retirement

Scanner status: runtime_validation_required | validation: dynamic

1. Enroll agents under an accountable sponsor and approved workload identity; verify identity claims before issuing credentials or granting discovery and execution access.
2. Test retirement, sponsor departure, redeployment, and identity compromise; remove stale credentials, cached grants, registrations, and downstream access.

<https://cloudsecurityalliance.org/artifacts/agentic-ai-identity-and-access-management-a-new-approach>

<https://www.nccoe.nist.gov/publications/other/accelerating-adoption-software-and-ai-agent-identity-an...>

MCP-01 / Validate transport exposure and origin

Scanner status: findings_detected | validation: hybrid

1. For HTTP, reject invalid Origin values and verify local deployments bind only to intended interfaces.
2. Use TLS for remote protected endpoints; test DNS rebinding and proxy/header behavior in deployment.

<https://modelcontextprotocol.io/specification/2026-07-28/basic/transports/streamable-http>

MCP-02 / Validate tool arguments and results

Scanner status: review_required | validation: hybrid

1. Apply schemas and semantic bounds before executing every tool; reject unknown properties where appropriate.
2. Bound sizes and nesting; validate declared structured output and render errors without leaking secrets.

<https://modelcontextprotocol.io/specification/2026-07-28/server/tools>

MCP-03 / Treat descriptions and annotations as untrusted

Scanner status: review_required | validation: hybrid

1. Inspect descriptions, schemas, resources, icons, and results for instructions that cross tool or user boundaries.
2. Never let readOnlyHint, destructiveHint, or other server claims replace independent authorization and approval policy.

<https://modelcontextprotocol.io/specification/2026-07-28/server/tools>

https://cheatsheetseries.owasp.org/cheatsheets/MCP_Security_Cheat_Sheet.html

MCP-04 / Detect tool substitution and metadata changes

Scanner status: review_required | validation: hybrid

1. Bind tool approval to verified server identity and the reviewed tool definition or version.
2. Revalidate changes after reconnect/list updates; disambiguate collisions across servers without trusting display names.

<https://owasp.org/projects/mcp-top-10>

MCP-05 / Protect state handles and legacy sessions

Scanner status: no_pattern_detected | validation: dynamic

1. Authorize every state handle against its owner and tenant; enforce expiry, unpredictability, and replay boundaries.
2. For older sessionful protocol versions, test session hijacking and cross-user resumption; a session ID is not authentication.

<https://modelcontextprotocol.io/specification/2026-07-28/server/tools>

https://modelcontextprotocol.io/docs/2026-07-28/tutorials/security/security_best_practices

MCP-06 / Constrain sampling and returned model context

Scanner status: runtime_validation_required | validation: dynamic

1. Apply host policy and user control to sampling requests, context sharing, model selection, and associated tool access.
2. Test whether an untrusted server can induce disclosure from unrelated conversations or recursively consume model budget.

<https://modelcontextprotocol.io/specification/2026-07-28/client/sampling>

MCP-07 / Secure elicitation and URL interactions

Scanner status: review_required | validation: hybrid

1. Keep sensitive credential collection out of form-mode elicitation; validate and visibly identify URL destinations.
2. Test cancellation, phishing URLs, unsolicited interactions, and replayed completion state against the selected protocol version.

<https://modelcontextprotocol.io/specification/2026-07-28/client/elicitation>



MCP-08 / Enforce filesystem isolation independently of roots

Scanner status: no_pattern_detected | validation: hybrid

1. Treat declared roots as scoped information, not an operating-system sandbox or complete authorization mechanism.
2. Enforce allowed paths at file access and test traversal, symlinks, alternate encodings, and writes outside the workspace.

<https://modelcontextprotocol.io/specification/2026-07-28/client/roots>

MCP-09 / Constrain local server launch and inherited environment

Scanner status: findings_detected | validation: hybrid

1. Approve executable and package identity before starting a stdio server; use argument arrays and a minimal environment.
2. Restrict proxy process-spawn APIs and child filesystem/network permissions; separate stdout protocol traffic from logs.

https://modelcontextprotocol.io/docs/2026-07-28/tutorials/security/security_best_practices

https://cheatsheetseries.owasp.org/cheatsheets/MCP_Security_Cheat_Sheet.html

MCP-10 / Apply version-aware metadata, caching, and cancellation

Scanner status: runtime_validation_required | validation: dynamic

1. Record supported revisions and test their capability, metadata, header consistency, stream, and cancellation rules.
2. Prevent caches and request continuations from crossing authorization contexts; do not apply legacy handshake assumptions universally.

<https://modelcontextprotocol.io/specification/2026-07-28/basic/transport>

<https://modelcontextprotocol.io/specification/2026-07-28/basic/transport/streamable-http>

AGT-01 / Enforce action policy outside the model

Scanner status: findings_detected | validation: hybrid

1. Place allow/deny decisions at the execution boundary using trusted policy inputs and constrained tool capabilities.
2. Show that an injected instruction cannot disable policy, choose privileged credentials, or bypass approval.

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/agent-ai-harnesses>

AGT-02 / Bind approval to the action executed

Scanner status: findings_detected | validation: dynamic

1. Present actual recipient, target, arguments, data disclosure, and consequences for high-impact approval.
2. Invalidate approval if arguments or target change; test races, delayed retries, and approval reuse.

https://cheatsheetseries.owasp.org/cheatsheets/AI_Agent_Security_Cheat_Sheet.html

AGT-03 / Separate untrusted content from authoritative instructions

Scanner status: no_pattern_detected | validation: hybrid

1. Track origin and trust level for web pages, documents, messages, OCR, tool results, and repository instructions.
2. Test direct and indirect goal hijacking; formatting delimiters and prompt warnings alone are not access controls.

<https://genai.owasp.org/resource/owasp-genai-llm-top-10-2026/>

AGT-04 / Protect retrieval and persistent memory

Scanner status: review_required | validation: hybrid

1. Enforce document and memory ACLs at retrieval and update time, including vector search metadata filters.
2. Test poisoned memory persistence, cross-tenant retrieval, provenance loss, deletion, and stale privileged context.

<https://genai.owasp.org/resource/owasp-top-10-for-agent-ai-applications-for-2026/>

AGT-05 / Keep objectives and authority bounded across agents

Scanner status: runtime_validation_required | validation: dynamic

1. Constrain delegated tasks and verify messages against authenticated senders, expected schemas, and allowed transitions.
2. Test impersonation, conflicting instructions, cascading failure, and privilege growth across handoffs.

<https://genai.owasp.org/resource/owasp-top-10-for-agent-ai-applications-for-2026/>



AGT-06 / Protect agent configuration and skills

Scanner status: review_required | validation: hybrid

1. Inventory skill files, prompts, hooks, memory seed files, MCP configuration, and other executable workflow inputs.
2. Require review for changes that add commands, access, or persistence; external repository text cannot become trusted policy.

<https://github.com/mitre-atlas/atlas-data>

<https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development>

AGT-07 / Prevent sensitive context leaving through legitimate tools

Scanner status: runtime_validation_required | validation: dynamic

1. Apply destination and data policies to URLs, searches, tickets, messages, uploads, and telemetry generated by agents.
2. Use canary data to test encoded leakage and combinations of otherwise permitted tools.

https://cheatsheetseries.owasp.org/cheatsheets/MCP_Security_Cheat_Sheet.html

EXEC-01 / Prevent shell and command injection

Scanner status: findings_detected | validation: hybrid

1. Find shell execution and constructed command strings; use fixed executables, argument arrays, and allowed argument values.
2. Test untrusted tool inputs containing shell syntax, option injection, command substitution, and hostile filenames.

<https://owasp.org/projects/mcp-top-10>

<https://genai.owasp.org/llmrisk/llm052025-improper-output-handling/>

EXEC-02 / Constrain generated-code execution

Scanner status: findings_detected | validation: hybrid

1. Locate eval, exec, dynamic imports, templates, notebooks, and interpreter tools accepting model or user content.
2. Run required code execution in a disposable restricted environment with explicit filesystem, network, CPU, and time limits.

https://cheatsheetseries.owasp.org/cheatsheets/AI_Agent_Security_Cheat_Sheet.html

EXEC-03 / Parameterize database and query operations

Scanner status: no_pattern_detected | validation: hybrid

1. Use bound query parameters and allowed query shapes; inspect SQL, NoSQL, graph, and search-language construction.
2. Separate read/write database identities and test whether generated queries can escape permitted objects or operations.

<https://genai.owasp.org/llmrisk/llm052025-improper-output-handling/>

EXEC-04 / Constrain file and archive access

Scanner status: no_pattern_detected | validation: hybrid

1. Resolve and enforce allowed paths at access time; constrain uploads, downloads, extraction, temporary files, and permissions.
2. Test symlink races, archive traversal, absolute paths, overwrite attempts, and secret-directory reads.

<https://modelcontextprotocol.io/specification/2026-07-28/client/roots>

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/deploying-ai-syste...>

EXEC-05 / Prevent SSRF and unsafe network destinations

Scanner status: no_pattern_detected | validation: hybrid

1. Restrict destinations and schemes at connection time; revalidate DNS resolution and each redirect.
2. Test loopback, private/link-local IPv4 and IPv6, cloud metadata, alternate encodings, and redirect-to-private cases.

https://modelcontextprotocol.io/docs/2026-07-28/tutorials/security/security_best_practices

EXEC-06 / Reject unsafe parsing and deserialization

Scanner status: findings_detected | validation: hybrid

1. Inspect pickle, unsafe YAML, object deserialization, XML entity expansion, and unconstrained recursive parsers.
2. Use data-only formats with byte, nesting, and type limits; test malformed input and expansion attacks.

<https://csrc.nist.gov/pubs/sp/800/218/final>



EXEC-07 / Render model and tool output safely

Scanner status: no_pattern_detected | validation: hybrid

1. Use context-specific escaping for HTML/Markdown, avoid unsafe DOM sinks, and validate links and embedded media.
2. Test active SVG/HTML, malicious URLs, terminal escapes, and spreadsheet formulas in exported reports.

<https://genai.owasp.org/llmrisk/llm052025-improper-output-handling/>

DATA-01 / Detect and remove embedded credentials

Scanner status: findings_detected | validation: static

1. Inspect code, examples, configuration, notebooks, test fixtures, and generated artifacts for secret-like values.
2. Verify actual exposures with the owner, rotate real credentials, and remove them from reachable history and artifacts.

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/deploying-ai-syste...>

DATA-02 / Minimize data sent to models and gateways

Scanner status: manual_review_required | validation: manual

1. Map which prompts, tool outputs, memory, and code leave the environment and identify the receiving provider/gateway.
2. Document allowed data classes, processing location, retention, and training use; redact before transmission where required.

<https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf>

DATA-03 / Protect logs, traces, and error responses

Scanner status: no_pattern_detected | validation: hybrid

1. Redact secrets and sensitive payloads before logs, traces, exception strings, and dashboards persist them.
2. Test the failure paths and provider errors as well as success paths; restrict access and export destinations.

<https://owasp.org/projects/mcp-top-10>

DATA-04 / Track provenance and integrity of AI data

Scanner status: manual_review_required | validation: manual

1. Record source, owner, version, transformation history, and integrity evidence for datasets, retrieval corpora, and memory seeds.
2. Quarantine unexpected changes and test how poisoned or stale data is detected, removed, and replaced.

<https://www.nsa.gov/Press-Room/Press-Releases-Statements/Press-Release-View/Article/4192332/nsas-aisc...>

DATA-05 / Enforce retention and deletion across copies

Scanner status: runtime_validation_required | validation: dynamic

1. Apply expiry and deletion to prompts, embeddings, caches, memory, tool artifacts, backups, and provider-held data.
2. Verify deleting a source record removes or invalidates dependent retrieval content and access grants.

<https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf>

DATA-06 / Protect stored data and keys

Scanner status: review_required | validation: hybrid

1. Check transport verification, storage access controls, encryption settings, key separation, and backup permissions.
2. Validate key rotation and denied access using a principal outside the authorized tenant or operational role.

<https://www.nsa.gov/Press-Room/Press-Releases-Statements/Press-Release-View/Article/4192332/nsas-aisc...>

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/deploying-ai-syste...>

SUP-01 / Pin and inventory executable dependencies

Scanner status: findings_detected | validation: static

1. Review lockfiles and exact versions or immutable digests for packages, images, MCP servers, models, and plugins.
2. Flag runtime installs, floating tags, remote scripts, and dependency sources outside approved registries.

<https://csrc.nist.gov/pubs/sp/800/218/final>



SUP-02 / Check vulnerability and maintenance exposure

Scanner status: manual_review_required | validation: manual

1. Run appropriate package/container advisory tools against resolved dependencies and save database date and tool version.
2. Triage reachability, fix availability, support status, and transitive dependencies; source pattern scans do not establish CVE coverage.

<https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development>

SUP-03 / Verify artifact identity and provenance

Scanner status: findings_detected | validation: manual

1. Verify publisher identity, hashes/signatures, build provenance, and intended origin before enabling artifacts.
2. Review model loading and serialization behavior; an integrity hash cannot make an untrusted publisher safe.

<https://www.nsa.gov/Press-Room/Press-Releases-Statements/Press-Release-View/Article/4192332/nsas-aisc...>

<https://csrc.nist.gov/pubs/sp/800/218/final>

SUP-04 / Protect build, release, and configuration changes

Scanner status: no_pattern_detected | validation: hybrid

1. Restrict CI credentials and workflow permissions; review actions, build scripts, and release provenance.
2. Prevent untrusted contributions from executing with deployment secrets or changing approved agent policies.

<https://csrc.nist.gov/pubs/sp/800/218/final>

SUP-05 / Harden runtime isolation and deployment defaults

Scanner status: findings_detected | validation: hybrid

1. Review root/privileged containers, host mounts, Docker sockets, unrestricted egress, debug mode, and public management endpoints.
2. Separate agent execution from control-plane credentials and audit storage; test isolation in the deployed environment.

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/deploying-ai-syste...>

SUP-06 / Separate and protect model development environments

Scanner status: runtime_validation_required | validation: dynamic

1. When training or fine-tuning, isolate development, evaluation, and production identities, data access, registries, and release permissions.
2. Protect datasets, weights, adapters, and configuration separately; monitor modifications and demonstrate that an untrusted training job cannot replace an approved production artifact.

<https://csrc.nist.gov/pubs/sp/800/218/a/final>

OPS-01 / Produce attributable audit events

Scanner status: review_required | validation: hybrid

1. Record initiating identity, delegated identity, tool/server/version, approved arguments, decision, outcome, and correlation identifiers.
2. Protect log integrity and clock consistency; ensure agents cannot erase their own action history.

<https://owasp.org/projects/mcp-top-10>

OPS-02 / Bound work, spending, and concurrency

Scanner status: review_required | validation: hybrid

1. Set server-enforced limits for iterations, tokens, tool calls, recursion, parallelism, bytes, cost, and elapsed time.
2. Exercise stuck loops and amplification paths; verify limits apply across retries and child agents.

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/agent-ai-harnesses>

OPS-03 / Make cancellation and shutdown effective

Scanner status: runtime_validation_required | validation: dynamic

1. Provide a tested stop mechanism that revokes work, credentials, queued actions, and child tasks.
2. Measure stop latency and verify cancelled or disconnected requests cannot later commit prohibited side effects.

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/careful-adoption-o...>



OPS-04 / Fail safely and prevent duplicate side effects

Scanner status: runtime_validation_required | validation: dynamic

1. Deny or escalate when policy, identity, or approval checks fail; prevent fallback paths from widening privilege.
2. Test outages, partial failures, timeouts, retries, idempotency, and recovery of transactions with external effects.

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/agent-ai-harnesses>

OPS-05 / Monitor behavior and support rollback

Scanner status: runtime_validation_required | validation: dynamic

1. Alert on unusual tool use, new destinations, scope growth, repeated denials, cost spikes, and unexpected state changes.
2. Validate alerts with seeded events and test rollback of models, prompts, tools, policies, and poisoned memory.

<https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development>

OPS-06 / Practice incident response and disclosure

Scanner status: manual_review_required | validation: manual

1. Maintain procedures to isolate agents, revoke credentials, preserve evidence, notify owners, and recover trusted state.
2. Exercise an AI-specific incident and define approved vulnerability/intelligence-sharing channels without exposing sensitive evidence.

<https://www.cisa.gov/news-events/alerts/2025/01/14/cisa-releases-jcdc-ai-cybersecurity-collaboration-...>

TEST-01 / Measure prompt-injection security and useful task completion

Scanner status: runtime_validation_required | validation: dynamic

1. Run paired benign and adversarial workflows with representative tools and attacker-controlled external content.
2. Record attacker success, authorized task success, blocked benign actions, and the observed unauthorized side effect.

<https://github.com/ethz-spylab/agentdojo>

<https://github.com/uiuc-kang-lab/InjecAgent>

TEST-02 / Test adaptively and repeat scenarios

Scanner status: runtime_validation_required | validation: dynamic

1. Vary payload wording, placement, modality, attacker knowledge, and attempts; rerun after changing defenses.
2. Report per-scenario outcomes, sample counts, attack budget, uncertainty, and model/harness versions instead of only an average.

<https://www.nist.gov/news-events/news/2025/01/technical-blog-strengthening-ai-agent-hijacking-evaluat...>

TEST-03 / Exercise MCP authentication and protocol abuse

Scanner status: runtime_validation_required | validation: dynamic

1. In an isolated test environment, exercise invalid tokens, wrong audiences, origin abuse, malicious servers, and protocol fuzzing.
2. Adapt scenarios to the deployed MCP revision and transports; preserve request/response evidence with secrets removed.

<https://github.com/AIS2Lab/MCPSecBench>

<https://modelcontextprotocol.io/specification/2026-07-28/basic/authorization>

TEST-04 / Verify cross-tenant and cross-agent isolation

Scanner status: runtime_validation_required | validation: dynamic

1. Create two principals and attempt cross-access to objects, memory, caches, handles, subscriptions, and execution results.
2. Repeat after reconnect, delegation, failed authentication, concurrent requests, and privilege revocation.

<https://github.com/agiresearch/ASB>

TEST-05 / Test approval, policy, and sandbox bypass

Scanner status: runtime_validation_required | validation: dynamic

1. Use explicit forbidden-action canaries to verify enforcement survives hostile content, tool substitution, and delayed execution.
2. Confirm paths through retries, fallback models, alternate tools, and child agents enforce the same boundary.

https://cheatsheetseries.owasp.org/cheatsheets/AI_Agent_Security_Cheat_Sheet.html



TEST-06 / Verify conventional application security

Scanner status: runtime_validation_required | validation: dynamic

1. Run language-aware SAST, dependency review, secret scanning, and authorized integration tests for exposed services.
2. Exercise reachable injection, XSS, SSRF, path traversal, deserialization, and access-control risks with safe fixtures.

<https://csrc.nist.gov/pubs/sp/800/218/final>

<https://genai.owasp.org/llmrisk/llm052025-improper-output-handling/>

TEST-07 / Validate resource exhaustion and observability

Scanner status: runtime_validation_required | validation: dynamic

1. Simulate oversized messages, slow peers, streaming floods, repeated errors, runaway agents, and unavailable dependencies.
2. Verify quotas, shutdown, telemetry, and alerts work together without leaking payloads or losing attribution.

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/autonomous-ai-harnesses>

TEST-08 / Evaluate the optional security judge itself

Scanner status: runtime_validation_required | validation: dynamic

1. Treat repository text and model verdicts as untrusted; test prompt injection, fabricated locations, invalid JSON, and timeouts.
2. Compare against labeled cases, retain deterministic results, document model variability, and never equate a judge approval with control validation.

<https://www.nist.gov/news-events/news/2025/01/technical-blog-strengthening-ai-agent-hijacking-evaluat...>

<https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf>

TEST-09 / Evaluate model-layer attacks for hosted or customized models

Scanner status: runtime_validation_required | validation: dynamic

1. Where applicable, assess suspicious triggers, model extraction, and disclosure of private training examples under an explicit attacker access and query budget.
2. Retest acquired or retrained models and adapters before release; document measured failures, model identity, coverage limits, and accepted residual risk.

<https://cloudsecurityalliance.org/blog/2025/02/06/autonomous-ai-threat-modeling-framework-maestro>

<https://csrc.nist.gov/pubs/sp/800/218/a/final>